

BAN CƠ YẾU CHÍNH PHỦ
HỌC VIỆN KỸ THUẬT MẬT MÃ



CHUYÊN ĐỀ CƠ SỞ AN TOÀN HỆ THỐNG THÔNG TIN

**ĐÁNH GIÁ VÀ KIỂM TOÁN AN TOÀN CHO HỆ THỐNG
WEBSITE THƯƠNG MẠI ĐIỆN TỬ**

Ngành: An toàn thông tin

Sinh viên thực hiện:

Cao Khánh Trường - Mã SV: AT190554

Người hướng dẫn:

TS. Trần Anh Tú

Khoa An toàn thông tin – Học viện Kỹ thuật mật mã

Hà Nội, 2025

MỤC LỤC

Danh mục từ viết tắt	iv
Danh mục hình vẽ	v
Danh mục bảng	vi
Lời cảm ơn	vii
Lời nói đầu	viii
Chương 1. AN TOÀN ỨNG DỤNG WEB THƯƠNG MẠI ĐIỆN TỬ	1
1.1. Thực trạng hiện nay	1
1.2. Các mối đe dọa điển hình	2
1.2.1. Tấn công DDoS	2
1.2.2. Tấn công Cross-Site Scripting (XSS)	5
1.2.3. Tấn công SQL Injection	8
1.2.4. Tấn công Cross-Site Request Forgery (CSRF)	10
1.2.5. Rủi ro an toàn thông tin từ chatbot	13
1.3. Các thành phần an toàn	15
1.3.1. Ứng dụng giao thức HTTPS	15
1.3.2. Xác thực hai yếu tố	16
1.3.3. Web Application Firewall	16
1.3.4. IDPS	18
1.3.5. SIEM	20
1.3.6. Quản trị bí mật và DevSecOps	21
1.3.7. Các thành phần hỗ trợ	21
1.4. Yêu cầu an toàn và các tiêu chí đánh giá	22
1.5. Cơ sở lý thuyết rút gọn	23
1.6. Kết luận chương 1	23
Chương 2. GIẢI PHÁP AN TOÀN CHO WEBSITE THƯƠNG MẠI ĐIỆN TỬ	25
2.1. Giải pháp tại lớp ứng dụng	25
2.1.1. Xác thực và phân quyền	26
2.1.2. Chống SQL Injection	28
2.1.3. Chống XSS	30
2.2. Giải pháp an toàn cho Chatbot	33
2.2.1. Kiểm soát dữ liệu đầu vào và logic xử lý của chatbot	33
2.2.2. Giới hạn quyền truy cập của chatbot đối với hệ thống backend	34
2.2.3. Ghi log và giám sát hoạt động chatbot thông qua hệ thống SIEM	34
2.3. Firewall và Web Application Firewall	35
2.3.1. Firewall trong hệ thống website thương mại điện tử	35
2.3.2. Kết hợp Firewall và WAF trong mô hình phòng thủ nhiều lớp	36

2.3.3. Nhận xét	37
2.4. Siem	37
2.5. Luồng thực thi của hệ thống	39
2.5.1. Luồng xử lý yêu cầu truy cập và nghiệp vụ	40
2.5.2. Luồng giám sát và xử lý sự kiện an toàn	40
2.5.3. Ý nghĩa của luồng thực thi đối với an toàn hệ thống	41
2.6. Kết luận chương 2	41
Chương 3. Triển khai thực nghiệm và đánh giá	43
3.1. Mô hình hệ thống triển khai	43
3.2. Kịch bản kiểm thử	44
3.2.1. Kịch bản 1 (Cross-Site Scripting)	44
3.2.2. Kịch bản 2 (DDoS)	48
3.2.3. Kịch bản 3 (SQL Injection)	52
3.3. Thu thập và trình bày kết quả	55
3.4. Kết luận chương 3	56
Kết luận	57
Tài liệu tham khảo	59
Phụ lục	60

BÁO CÁO BÀI TẬP LỚN

[illegible]

Điểm báo cáo:.....

111

DANH MỤC TỪ VIẾT TẮT

WAF	Web Application Firewall
DDoS	Distributed Denial of Service
XSS	Cross-Site Scripting
SIEM	Security Information and Event Management
IDPS	Intrusion Detection and Prevention System
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
DB	Database
OSI	Open Systems Interconnection
CSDL	Cơ sở dữ liệu
IP	Internet Protocol
SQL	Structured Query Language
URL	Uniform Resource Locator
CPU	Central Processing Unit
RAM	Random Access Memory

DANH MỤC HÌNH VẼ

<i>Hình 1.1 Minh họa 1 cuộc tấn công DDoS</i>	3
<i>Hình 1.2 Sơ đồ hoạt động của 1 cuộc tấn công XSS</i>	5
<i>Hình 1.3 Minh họa 1 cuộc tấn công SQL Injection</i>	8
<i>Hình 1.4 Chức năng của tường lửa ứng dụng web</i>	17
<i>Hình 2.1 Ứng dụng của Firewall và WAF</i>	36
<i>Hình 3.1 Sơ đồ hệ thống triển khai thực nghiệm</i>	44
<i>Hình 3.2 Khởi chạy SIEM trên máy chủ</i>	45
<i>Hình 3.3 Chạy Web Server trên máy chủ</i>	46
<i>Hình 3.4 Attacker thực hiện thăm dò và tấn công XSS</i>	46
<i>Hình 3.5 Hệ thống phát hiện chuỗi <script> bất thường và gửi cảnh báo</i>	47
<i>Hình 3.6 Mã nguồn chứa lỗ hổng cho phép thực thi mã trong comment</i>	47
<i>Hình 3.7 Thực hiện và lỗ hổng</i>	47
<i>Hình 3.8 Bằng chứng cho việc vá lỗ hổng XSS thành công</i>	48
<i>Hình 3.9 Hệ thống vẫn gửi cảnh báo với các trường hợp có ý định xấu</i>	48
<i>Hình 3.10 Cấu hình phát hiện và gửi cảnh báo nghi ngờ DDoS</i>	49
<i>Hình 3.11 Thực hiện gửi liên tục các request đến website</i>	50
<i>Hình 3.12 Hệ thống giám sát phát cảnh báo</i>	50
<i>Hình 3.13 Tự động thêm địa chỉ IP vào danh sách chặn</i>	51
<i>Hình 3.14 Thực hiện ngăn chặn các IP trong danh sách</i>	51
<i>Hình 3.15 Kết quả hacker không còn truy cập được website sau khi bị chặn</i>	52
<i>Hình 3.16 Thực hiện khai thác cấu trúc CSDL</i>	53
<i>Hình 3.17 Kết quả hiển thị các bảng danh mục trong CSDL</i>	54
<i>Hình 3.18 SIEM ghi nhận và phát cảnh báo, tự động thêm IP vào blocklist</i>	54

DANH MỤC BẢNG

<i>Bảng 1.1 Đối chiếu vai trò của WAF với các mối đe dọa</i>	<i>18</i>
<i>Bảng 1.2 Vai trò của IDPS trong chuỗi phòng thủ</i>	<i>19</i>
<i>Bảng 1.3 Vai trò của SIEM trong phát hiện tấn công phức hợp</i>	<i>21</i>
<i>Bảng 1.4 Tiêu chí đánh giá mức độ an toàn</i>	<i>22</i>
<i>Bảng 2.1 Đánh giá mức độ an toàn trước và sau khi áp dụng giải pháp xác thực và phân quyền</i>	<i>27</i>
<i>Bảng 2.2 Phân tích nguyên nhân – hậu quả – giải pháp đối với SQL Injection</i>	<i>30</i>
<i>Bảng 2.3 So sánh tác động trước và sau khi áp dụng giải pháp</i>	<i>30</i>
<i>Bảng 2.4 Phân tích lỗ hổng XSS trong website thương mại điện tử</i>	<i>33</i>
<i>Bảng 2.5 So sánh Firewall và Web Application Firewall</i>	<i>36</i>
<i>Bảng 2.6 Hiệu quả bảo vệ khi kết hợp Firewall và WAF</i>	<i>37</i>
<i>Bảng 2.7 Các nguồn log và vai trò trong hệ thống SIEM</i>	<i>39</i>
<i>Bảng 2.8 Hiệu quả giám sát an toàn trước và sau khi triển khai SIEM</i>	<i>39</i>
<i>Bảng 2.9 Tóm tắt luồng thực thi an toàn của hệ thống</i>	<i>41</i>
<i>Bảng 3.1 Tổng hợp kết quả thực nghiệm</i>	<i>56</i>

LỜI CẢM ƠN

Trong suốt quá trình nghiên cứu và thực hiện đề tài, em xin bày tỏ lòng biết ơn chân thành tới ThS. Trần Anh Tú – giảng viên hướng dẫn, người đã tận tình hỗ trợ, định hướng và đưa ra những nhận xét quý báu trong suốt quá trình em thực hiện đề tài. Sự đồng hành và hướng dẫn của thầy là yếu tố quan trọng giúp em vượt qua những khó khăn và hoàn thiện báo cáo này.

Em cũng xin gửi lời cảm ơn tới các anh chị và các bạn học, những người đã chia sẻ tài liệu, kinh nghiệm thực tiễn và hỗ trợ em trong quá trình tìm hiểu và triển khai đề tài. Sự giúp đỡ của các anh chị và các bạn đã góp phần quan trọng vào việc nâng cao chất lượng nghiên cứu cũng như kỹ năng làm việc của em.

Xin cảm ơn tất cả mọi người đã động viên, góp ý và hỗ trợ tinh thần trong suốt quá trình làm việc. Những đóng góp ấy là nguồn động lực để em hoàn thành đề tài một cách nghiêm túc và hiệu quả nhất.

SINH VIÊN THỰC HIỆN ĐỀ TÀI

Cao Khánh Trường

LỜI NÓI ĐẦU

Trong bối cảnh chuyển đổi số diễn ra mạnh mẽ, các website thương mại điện tử ngày càng đóng vai trò quan trọng trong hoạt động kinh doanh của doanh nghiệp. Các hệ thống này không chỉ xử lý khối lượng lớn dữ liệu người dùng mà còn liên quan trực tiếp đến các giao dịch tài chính và thông tin nhạy cảm. Do đó, vấn đề đảm bảo an toàn thông tin cho website thương mại điện tử trở thành yêu cầu cấp thiết.

Tuy nhiên, thực tế cho thấy nhiều hệ thống thương mại điện tử hiện nay vẫn tồn tại các lỗ hổng bảo mật do hạn chế trong thiết kế, triển khai và vận hành. Các lỗ hổng này có thể bị khai thác bởi các hình thức tấn công phổ biến như tấn công từ chối dịch vụ, tấn công chèn mã độc hay tấn công vào cơ sở dữ liệu, gây ra những thiệt hại nghiêm trọng về kinh tế và uy tín.

Xuất phát từ thực tiễn đó, đề tài tập trung vào việc đánh giá hiện trạng an toàn thông tin của một hệ thống website thương mại điện tử và đề xuất các giải pháp kiến tạo an toàn nhằm nâng cao khả năng phòng thủ, phát hiện và ứng phó trước các mối đe dọa an ninh mạng.

SINH VIÊN THỰC HIỆN ĐỀ TÀI

Cao Khánh Trường

CHƯƠNG 1. AN TOÀN ỨNG DỤNG WEB THƯƠNG MẠI ĐIỆN TỬ

1.1. Thực trạng hiện nay

Trong những năm gần đây, thương mại điện tử đã và đang phát triển mạnh mẽ trên phạm vi toàn cầu, trở thành một trong những lĩnh vực có tốc độ tăng trưởng nhanh nhất của nền kinh tế số. Sự phổ biến của Internet, thiết bị di động và các phương thức thanh toán điện tử đã thúc đẩy nhu cầu mua sắm trực tuyến của người tiêu dùng. Đối với doanh nghiệp, website thương mại điện tử không chỉ là kênh bán hàng mà còn là công cụ quan trọng để tiếp cận khách hàng, mở rộng thị trường và nâng cao năng lực cạnh tranh.

Cùng với sự gia tăng về nhu cầu sử dụng, các hệ thống thương mại điện tử ngày càng được phát triển với nhiều chức năng phức tạp hơn, bao gồm quản lý người dùng, quản lý sản phẩm, xử lý đơn hàng, thanh toán trực tuyến và tích hợp với các hệ thống bên thứ ba. Các hệ thống này thường được triển khai trên nền tảng web, hoạt động liên tục và phục vụ đồng thời một số lượng lớn người dùng. Do đó, website thương mại điện tử trở thành một thành phần hạ tầng thông tin quan trọng đối với doanh nghiệp.

Tuy nhiên, thực tế cho thấy vấn đề an toàn thông tin đối với các hệ thống website thương mại điện tử vẫn chưa được quan tâm đúng mức. Nhiều hệ thống được phát triển với trọng tâm là chức năng và hiệu năng, trong khi các yêu cầu về bảo mật chỉ được xem xét ở mức cơ bản hoặc mang tính đối phó. Việc thiếu các cơ chế bảo vệ phù hợp ở tầng ứng dụng, cấu hình hệ thống chưa chặt chẽ và không có giám sát an ninh tập trung khiến các website thương mại điện tử dễ trở thành mục tiêu của các cuộc tấn công mạng.

Các rủi ro an toàn đối với website thương mại điện tử bao gồm rò rỉ dữ liệu người dùng, mất quyền kiểm soát hệ thống, gián đoạn dịch vụ và gian lận trong giao dịch. Những rủi ro này không chỉ gây thiệt hại về mặt kỹ thuật mà còn kéo theo các chi phí đáng kể liên quan đến khắc phục sự cố, khôi phục hệ thống và xử lý hậu quả pháp lý. Ngoài ra, việc hệ thống bị tấn công hoặc gián đoạn còn ảnh hưởng nghiêm trọng đến uy tín và niềm tin của khách hàng đối với doanh nghiệp.

Về mặt vận hành, nhiều website thương mại điện tử hiện nay chưa có quy trình quản lý an toàn thông tin bài bản. Công tác giám sát, phát hiện và ứng phó sự cố an ninh còn mang tính thủ công hoặc bị phân tán giữa các thành phần hệ thống. Điều này làm giảm khả năng phát hiện sớm các hành vi tấn công và khiến việc xử lý sự cố trở nên chậm trễ, kém hiệu quả.

Từ thực trạng trên có thể thấy rằng, cùng với sự phát triển mạnh mẽ của thương mại điện tử, việc **đánh giá và kiểm toán an toàn thông tin cho các hệ thống website thương mại điện tử** là yêu cầu cần thiết nhằm đảm bảo hoạt động ổn định, an toàn và bền vững của hệ thống.

1.2. Các mối đe dọa điển hình

Trong môi trường Internet mở, các hệ thống website thương mại điện tử phải đối mặt với nhiều mối đe dọa an toàn thông tin đến từ cả bên ngoài và bên trong hệ thống. Các mối đe dọa này xuất phát từ nhiều nguyên nhân khác nhau như lỗ hổng phần mềm, cấu hình hệ thống chưa phù hợp, thiếu cơ chế kiểm soát truy cập hoặc do hành vi cố ý của các đối tượng tấn công.

Đặc điểm chung của các mối đe dọa đối với website thương mại điện tử là hướng tới việc khai thác tài nguyên hệ thống, chiếm đoạt dữ liệu hoặc làm gián đoạn dịch vụ. Do các hệ thống này thường hoạt động liên tục và phục vụ số lượng lớn người dùng, hậu quả của một sự cố an toàn thông tin có thể lan rộng và gây ảnh hưởng nghiêm trọng đến hoạt động kinh doanh.

Hậu quả tiềm ẩn của các mối đe dọa an toàn bao gồm:

- Gián đoạn hoặc mất hoàn toàn khả năng cung cấp dịch vụ cho người dùng hợp lệ
- Rò rỉ thông tin cá nhân và dữ liệu giao dịch của khách hàng
- Gian lận trong quá trình giao dịch trực tuyến
- Thiệt hại tài chính và suy giảm uy tín của doanh nghiệp

Trong bối cảnh đó, việc nhận diện các mối đe dọa điển hình là cơ sở quan trọng để đánh giá mức độ an toàn và đề xuất các biện pháp phòng vệ phù hợp.

1.2.1. Tấn công DDoS

Tấn công DDoS (Distributed Denial of Service) là hình thức tấn công nhằm phá vỡ tính sẵn sàng của hệ thống thông tin thông qua việc tạo ra lưu lượng truy cập hoặc yêu cầu xử lý vượt quá khả năng đáp ứng của hệ thống. Trong bối cảnh website thương mại điện tử, DDoS không đơn thuần là làm “sập website”, mà trực tiếp làm gián đoạn chuỗi giá trị kinh doanh số của doanh nghiệp.

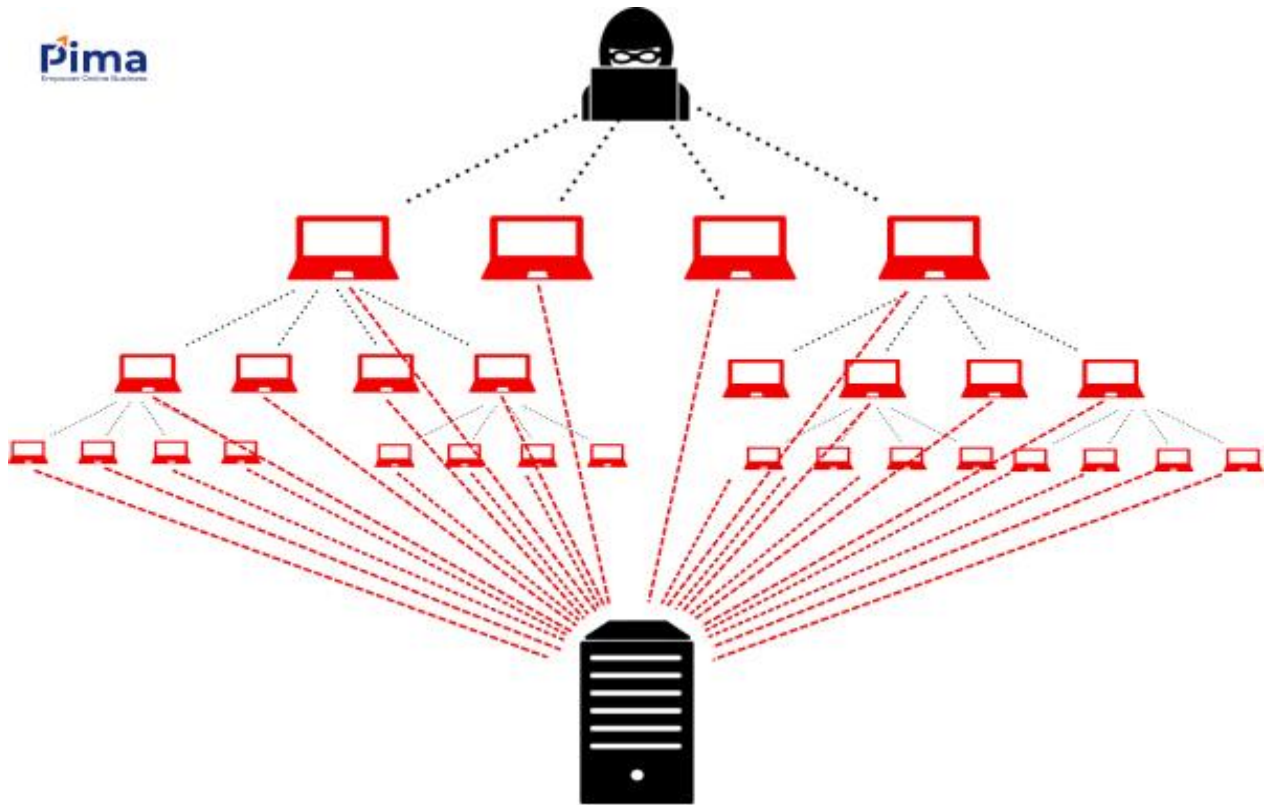
Khác với các hệ thống thông tin nội bộ, website thương mại điện tử có đặc điểm là:

- Mở hoàn toàn ra Internet

Phục vụ đồng thời số lượng lớn người dùng không xác định

- Hoạt động liên tục 24/7
- Phụ thuộc chặt chẽ vào các dịch vụ bên thứ ba (thanh toán, vận chuyển, xác thực)

Chính các đặc điểm này khiến DDoS trở thành mối đe dọa đặc biệt nguy hiểm đối với hệ thống thương mại điện tử.



Hình 1.1 Minh họa 1 cuộc tấn công DDoS

a) Cách thức

Kẻ tấn công thường sử dụng một mạng các thiết bị bị kiểm soát từ xa để tạo ra lưu lượng truy cập bất thường. Các yêu cầu được gửi đồng thời và liên tục đến máy chủ mục tiêu, làm cạn kiệt các tài nguyên như CPU, bộ nhớ, băng thông mạng hoặc số lượng kết nối cho phép.

Tấn công DDoS có thể được thực hiện ở nhiều mức khác nhau:

- Ở mức hạ tầng mạng, gây nghẽn băng thông
- Ở mức hệ thống, làm quá tải tài nguyên máy chủ
- Ở mức ứng dụng, tạo ra số lượng lớn các yêu cầu hợp lệ giả mạo

Quá trình tấn công DDoS vào website thương mại điện tử thường diễn ra theo một vòng đời rõ ràng, không mang tính ngẫu nhiên:

- Giai đoạn chuẩn bị:

Kẻ tấn công thu thập thông tin về kiến trúc hệ thống, năng lực chịu tải, thời điểm cao điểm truy cập (ví dụ: khuyến mãi, flash sale). Việc lựa chọn đúng thời điểm giúp tối đa hóa tác động với chi phí tấn công thấp hơn.

- Giai đoạn phát động tấn công:

Lưu lượng truy cập bất thường được tạo ra đồng thời từ nhiều nguồn, có thể mô phỏng hành vi người dùng hợp lệ như truy cập trang sản phẩm, tìm kiếm hoặc tiến hành thanh toán. Điều này khiến hệ thống khó phân biệt giữa lưu lượng thật và lưu lượng tấn công.

- Giai đoạn duy trì:

Tấn công được duy trì trong khoảng thời gian đủ dài để làm cạn kiệt tài nguyên hệ thống hoặc buộc doanh nghiệp phải mở rộng hạ tầng tạm thời, từ đó làm tăng chi phí vận hành.

b) Ảnh hưởng

Khi một website thương mại điện tử bị tấn công DDoS, kẻ tấn công có thể:

- Làm gián đoạn hoàn toàn quá trình truy cập và giao dịch của người dùng
- Gây mất khả năng xử lý đơn hàng và thanh toán trực tuyến
- Làm suy giảm hiệu năng hệ thống trong thời gian dài ngay cả sau khi tấn công kết thúc

Ảnh hưởng của DDoS không chỉ giới hạn ở khía cạnh kỹ thuật mà còn tác động trực tiếp đến doanh thu, uy tín và trải nghiệm người dùng.

c) Nguyên nhân

Các lỗ hổng dẫn đến DDoS trong website thương mại điện tử thường không xuất phát từ lỗi lập trình đơn lẻ mà từ các vấn đề mang tính hệ thống:

- Kiến trúc triển khai tập trung, không có khả năng mở rộng linh hoạt
- Thiếu cơ chế phân tầng và cách ly giữa các thành phần hệ thống
- Không có chiến lược quản lý tải và phân tích hành vi truy cập
- Đánh giá thấp rủi ro DDoS trong giai đoạn thiết kế hệ thống

Điều này cho thấy DDoS là vấn đề của thiết kế và vận hành, không chỉ là vấn đề kỹ thuật thuần túy.

d) Nhận biết

Dấu hiệu của tấn công DDoS thường thể hiện qua việc lưu lượng truy cập tăng đột biến, thời gian phản hồi của hệ thống kéo dài hoặc website không thể truy cập trong khi không có thay đổi về cấu hình hoặc hạ tầng.

Việc nhận biết DDoS trong hệ thống website thương mại điện tử không chỉ dựa vào việc website không truy cập được mà còn thông qua các dấu hiệu vận hành:

- Lưu lượng truy cập tăng bất thường nhưng tỷ lệ chuyển đổi giảm mạnh
- Thời gian phản hồi tăng đồng loạt trên nhiều chức năng
- Log hệ thống ghi nhận số lượng lớn yêu cầu có hành vi lặp lại
- Các dịch vụ phụ trợ bị ảnh hưởng dây chuyền

Việc thiếu giám sát tập trung khiến nhiều hệ thống chỉ phát hiện DDoS khi sự cố đã xảy ra nghiêm trọng.

e) Phòng tránh

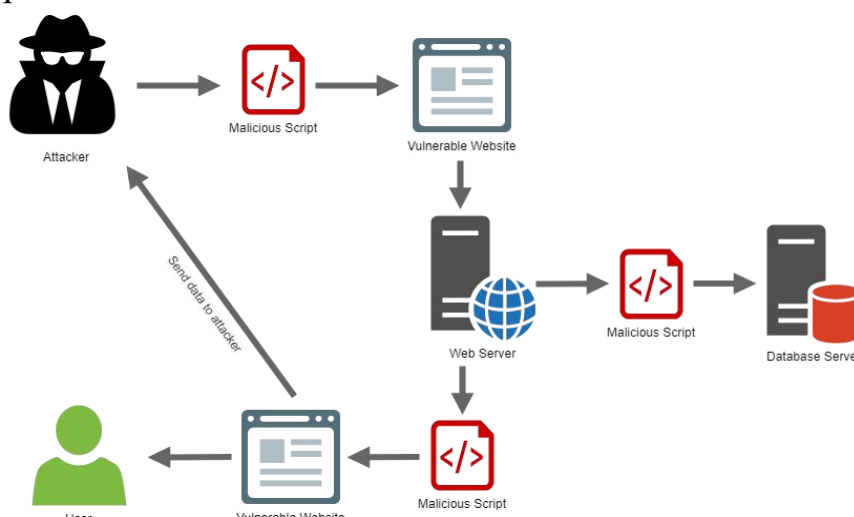
Phòng tránh DDoS trong website thương mại điện tử cần được xem là một phần của chiến lược kiến tạo an toàn hệ thống, bao gồm:

- Thiết kế kiến trúc có khả năng chịu tải và mở rộng
- Phân loại và kiểm soát lưu lượng truy cập theo hành vi
- Triển khai cơ chế giám sát liên tục và cảnh báo sớm
- Xây dựng quy trình ứng phó sự cố rõ ràng cho đội vận hành

Việc phòng tránh DDoS không chỉ giúp đảm bảo tính sẵn sàng mà còn góp phần ổn định hoạt động kinh doanh lâu dài.

1.2.2. Tấn công Cross-Site Scripting (XSS)

Cross-Site Scripting (XSS) là hình thức tấn công vào tầng ứng dụng web, trong đó kẻ tấn công khai thác các điểm xử lý dữ liệu không an toàn để chèn mã độc vào nội dung website. Mã độc này không được thực thi trên máy chủ mà trên chính trình duyệt của người dùng, lợi dụng sự tin cậy của người dùng đối với website hợp pháp.



Hình 1.2 Sơ đồ hoạt động của 1 cuộc tấn công XSS

Trong bối cảnh website thương mại điện tử, XSS đặc biệt nguy hiểm do hệ thống thường yêu cầu người dùng đăng nhập, duy trì phiên làm việc và thực hiện các thao tác liên quan trực tiếp đến tài khoản và giao dịch tài chính. Do đó, XSS không chỉ là lỗ hổng kỹ thuật mà còn là mối đe dọa trực tiếp đến niềm tin của người dùng.

a) Cách thức

Trong các hệ thống thương mại điện tử, kẻ tấn công thường nhắm vào các chức năng cho phép người dùng nhập dữ liệu như đánh giá sản phẩm, tìm kiếm hoặc biểu mẫu liên hệ. Khi dữ liệu này không được kiểm soát chặt chẽ, mã độc có thể được lưu trữ hoặc phản hồi lại trình duyệt người dùng.

Quá trình tấn công XSS trong hệ thống thương mại điện tử thường diễn ra theo các bước có chủ đích rõ ràng:

- Giai đoạn xác định điểm nhập dữ liệu:

Kẻ tấn công tiến hành rà soát các chức năng cho phép người dùng nhập dữ liệu như tìm kiếm sản phẩm, đánh giá, bình luận, biểu mẫu liên hệ hoặc thông tin hồ sơ cá nhân.

- Giai đoạn chèn mã độc:

Khi phát hiện các điểm nhập dữ liệu không được kiểm soát chặt chẽ, kẻ tấn công chèn các đoạn mã độc vào dữ liệu đầu vào. Nếu hệ thống lưu trữ hoặc phản hồi dữ liệu này mà không mã hóa an toàn, mã độc sẽ được nhúng vào nội dung trang web.

- Giai đoạn khai thác:

Mã độc được gửi đến trình duyệt của người dùng khác và thực thi trong bối cảnh của website thương mại điện tử, cho phép kẻ tấn công khai thác thông tin phiên làm việc hoặc thao tác thay người dùng.

Quá trình tấn công diễn ra âm thầm, khiến người dùng khó phát hiện và tiếp tục sử dụng website trong khi thông tin của họ đã bị khai thác.

b) Ảnh hưởng

Thông qua XSS, kẻ tấn công có thể:

- Đánh cắp thông tin phiên làm việc, từ đó chiếm quyền truy cập tài khoản người dùng.
- Thực hiện các hành vi thay người dùng như thay đổi thông tin cá nhân, đặt hàng hoặc hủy đơn.

- Chuyển hướng người dùng đến các trang web giả mạo nhằm lừa đảo thông tin.
- Phát tán mã độc thông qua website hợp pháp, làm suy giảm uy tín hệ thống.

Điểm nguy hiểm của XSS là các hành vi trên diễn ra dưới danh nghĩa người dùng hợp lệ, khiến việc phát hiện và truy vết trở nên khó khăn. XSS không trực tiếp phá hoại máy chủ nhưng gây tổn hại nghiêm trọng đến độ tin cậy và uy tín của hệ thống thương mại điện tử.

c) Nguyên nhân

Các lỗ hổng XSS trong website thương mại điện tử thường bắt nguồn từ các vấn đề mang tính thiết kế và phát triển ứng dụng:

- Ưu tiên chức năng và trải nghiệm người dùng hơn các yêu cầu an toàn.
- Thiếu cơ chế kiểm soát và xác thực dữ liệu đầu vào.
- Không thực hiện mã hóa dữ liệu đầu ra trước khi hiển thị.
- Nhận thức chưa đầy đủ của đội ngũ phát triển về các rủi ro an toàn ứng dụng web.

Những nguyên nhân này cho thấy XSS là hậu quả của việc thiếu tích hợp an toàn thông tin ngay từ giai đoạn phát triển hệ thống.

d) Nhận biết

XSS có thể được nhận biết thông qua các biểu hiện bất thường trên giao diện website, cảnh báo từ trình duyệt hoặc phản hồi tiêu cực từ người dùng về hành vi không mong muốn. Việc nhận biết XSS trong hệ thống thương mại điện tử thường không dễ dàng do mã độc được thực thi phía trình duyệt người dùng. Tuy nhiên, một số dấu hiệu có thể được quan sát trong quá trình vận hành:

- Nội dung hiển thị bất thường trên giao diện website.
- Người dùng phản ánh bị đăng xuất đột ngột hoặc có hành vi lạ trên tài khoản.
- Log hệ thống ghi nhận các yêu cầu chứa dữ liệu bất thường.
- Trình duyệt hoặc các công cụ bảo mật cảnh báo về nội dung không an toàn.

e) Phòng tránh

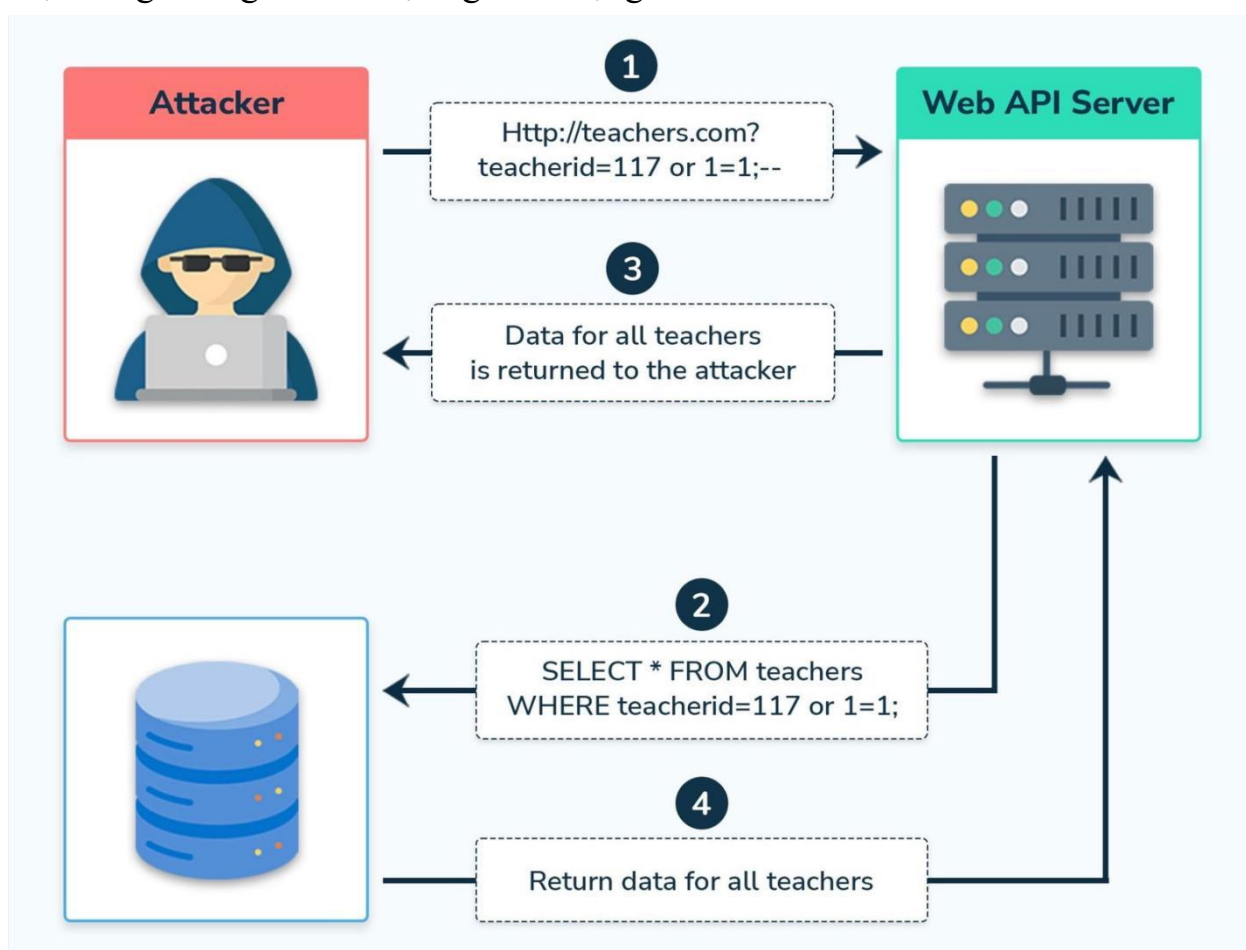
Phòng tránh XSS trong website thương mại điện tử đòi hỏi sự kết hợp giữa thiết kế an toàn và vận hành hiệu quả, bao gồm kiểm soát chặt chẽ dữ liệu đầu vào,

xử lý an toàn dữ liệu đầu ra và xây dựng các cơ chế hạn chế việc thực thi mã không mong muốn trên trình duyệt người dùng.

1.2.3. Tấn công SQL Injection

Trong website thương mại điện tử, cơ sở dữ liệu đóng vai trò trung tâm lưu trữ thông tin người dùng, sản phẩm, đơn hàng và giao dịch. SQL Injection là hình thức tấn công vào tầng dữ liệu của ứng dụng web, trong đó kẻ tấn công lợi dụng cách thức xây dựng câu lệnh truy vấn không an toàn để can thiệp vào logic xử lý dữ liệu của hệ thống. Thông qua SQL Injection, kẻ tấn công có thể truy cập, thay đổi hoặc phá hủy dữ liệu trong cơ sở dữ liệu.

Không giống các lỗi giao diện, SQL Injection tác động trực tiếp đến lỗi dữ liệu, nơi mọi hoạt động kinh doanh số được hình thành. Đối với website thương mại điện tử, cơ sở dữ liệu thường chứa những dữ liệu nhạy cảm như: thông tin khách hàng, tài khoản, đơn hàng và giao dịch, do đó SQL Injection được xem là một trong những mối đe dọa nghiêm trọng nhất.



Hình 1.3 Minh họa 1 cuộc tấn công SQL Injection

a) Cách thức

Kẻ tấn công thường nhắm vào các chức năng truy vấn dữ liệu như đăng nhập, tìm kiếm hoặc lọc sản phẩm. Khi dữ liệu đầu vào không được xử lý an toàn, các đoạn mã SQL độc hại có thể được thực thi trực tiếp trên hệ quản trị cơ sở dữ liệu.

Quá trình tấn công SQL Injection thường diễn ra theo một chuỗi các bước có hệ thống:

- Giai đoạn thăm dò:

Kẻ tấn công thử nghiệm các điểm nhập dữ liệu như chức năng đăng nhập, tìm kiếm hoặc lọc sản phẩm nhằm phát hiện các phản hồi bất thường của hệ thống.

- Giai đoạn khai thác:

Khi xác định được điểm yếu, kẻ tấn công chèn các đoạn mã SQL nhằm thay đổi logic truy vấn, từ đó truy xuất hoặc thao túng dữ liệu trong cơ sở dữ liệu.

- Giai đoạn mở rộng tác động:

Trong trường hợp hệ thống phân quyền không chặt chẽ, kẻ tấn công có thể tiếp tục leo thang đặc quyền, mở rộng phạm vi kiểm soát và gây thiệt hại nghiêm trọng hơn.

b) Ảnh hưởng

Thông qua SQL Injection, kẻ tấn công có thể:

- Truy xuất trái phép thông tin cá nhân và dữ liệu giao dịch của khách hàng
- Thay đổi hoặc xóa dữ liệu đơn hàng, gây rối loạn hoạt động kinh doanh
- Cài cắm dữ liệu giả mạo nhằm phục vụ các hành vi gian lận
- Trong một số trường hợp, chiếm quyền kiểm soát hệ thống máy chủ

Ảnh hưởng của SQL Injection thường mang tính lâu dài do dữ liệu bị xâm phạm khó có thể khôi phục hoàn toàn.

c) Nguyên nhân

Các lỗ hổng SQL Injection thường xuất phát từ:

- Việc xây dựng câu lệnh truy vấn bằng cách nối chuỗi trực tiếp
- Thiếu kiểm soát và làm sạch dữ liệu đầu vào
- Phân quyền tài khoản cơ sở dữ liệu không phù hợp
- Thiếu quy trình kiểm thử an toàn trước khi đưa hệ thống vào vận hành

Những nguyên nhân này phản ánh sự thiếu liên kết giữa phát triển ứng dụng và yêu cầu an toàn thông tin.

d) Nhận biết

Các dấu hiệu có thể bao gồm lỗi truy vấn bất thường, dữ liệu hiển thị sai lệch hoặc phản hồi không nhất quán của hệ thống khi xử lý dữ liệu.

SQL Injection có thể được nhận biết thông qua các dấu hiệu như:

- Các lỗi truy vấn bất thường xuất hiện trong log hệ thống
- Dữ liệu hiển thị sai lệch hoặc không nhất quán
- Hiệu năng truy vấn giảm đột ngột do truy vấn bị thao túng
- Các phản hồi bất thường khi xử lý dữ liệu đầu vào

e) Phòng tránh

Việc phòng tránh SQL Injection đòi hỏi xây dựng ứng dụng theo các nguyên tắc lập trình an toàn, kiểm soát dữ liệu đầu vào, phân quyền chặt chẽ cho tài khoản cơ sở dữ liệu và giám sát liên tục các hoạt động truy cập dữ liệu.

1.2.4. Tấn công Cross-Site Request Forgery (CSRF)

Cross-Site Request Forgery (CSRF) là một dạng tấn công ứng dụng web trong đó kẻ tấn công lợi dụng trạng thái xác thực hợp lệ của người dùng để ép trình duyệt nạn nhân thực hiện các yêu cầu (request) trái phép đến hệ thống mục tiêu mà người dùng không hề hay biết. Điểm đặc trưng của CSRF là không cần chiếm quyền điều khiển phiên đăng nhập, mà khai thác việc trình duyệt tự động đính kèm thông tin xác thực (cookie, session, token) trong mỗi yêu cầu gửi đến website.

Trong bối cảnh website thương mại điện tử, CSRF đặc biệt nguy hiểm vì nhiều thao tác quan trọng (thêm sản phẩm, đặt hàng, thay đổi thông tin tài khoản, thanh toán, liên kết ví...) được thực hiện thông qua các request HTTP có trạng thái (state-changing request).

a) Cách thức kẻ tấn công thực hiện CSRF

Quá trình tấn công CSRF thường diễn ra theo một chuỗi các bước có hệ thống, lợi dụng trạng thái xác thực hợp lệ của người dùng đối với hệ thống website thương mại điện tử:

- Giai đoạn chuẩn bị:

Người dùng đã đăng nhập vào website thương mại điện tử và phiên làm việc vẫn còn hiệu lực, cho phép trình duyệt tự động gửi kèm thông tin xác thực trong các request tiếp theo.

- Giai đoạn tạo yêu cầu giả mạo:

Kẻ tấn công xây dựng các request độc hại hướng tới các chức năng thay đổi trạng thái của hệ thống, sau đó nhúng các request này vào trang web hoặc nội dung trung gian.

- Giai đoạn thực thi:

Khi người dùng truy cập vào nội dung độc hại, trình duyệt tự động gửi request tới website mục tiêu kèm theo thông tin xác thực hợp lệ, khiến hệ thống xử lý yêu cầu như một thao tác hợp pháp của người dùng.

- Giai đoạn mở rộng tác động:

Nếu hệ thống không có cơ chế kiểm soát bổ sung, kẻ tấn công có thể tiếp tục khai thác CSRF để thực hiện nhiều hành vi trái phép khác nhau, gây ảnh hưởng đến dữ liệu, tài khoản người dùng và hoạt động của hệ thống.

Đặc điểm nguy hiểm của CSRF là request được gửi từ phía trình duyệt nạn nhân, khiến hệ thống backend khó phân biệt đâu là thao tác hợp lệ, đâu là thao tác bị giả mạo nếu không có cơ chế phòng vệ phù hợp.

b) Ảnh hưởng

Nếu khai thác thành công CSRF, kẻ tấn công có thể:

- Thực hiện các thao tác thay đổi trạng thái hệ thống thay cho người dùng:
 - Thay đổi thông tin tài khoản
 - Đặt hoặc hủy đơn hàng
 - Thay đổi địa chỉ nhận hàng
- Lợi dụng các chức năng thanh toán để gây thiệt hại tài chính
- Kết hợp CSRF với XSS hoặc SQL Injection để mở rộng phạm vi tấn công
- Làm suy giảm mức độ tin cậy và uy tín của hệ thống TMĐT

Đối với doanh nghiệp, CSRF không chỉ gây tổn thất trực tiếp về tài chính mà còn ảnh hưởng đến trải nghiệm người dùng và có thể dẫn đến vi phạm các yêu cầu về bảo vệ dữ liệu cá nhân.

c) Nguyên nhân phổ biến dẫn đến lỗ hổng CSRF

Các nguyên nhân chính khiến website thương mại điện tử dễ bị CSRF bao gồm:

- Không triển khai CSRF Token cho các request thay đổi trạng thái
- Chỉ dựa vào cookie phiên để xác thực yêu cầu
- Không kiểm tra hoặc kiểm tra không chặt chẽ các header như Origin và Referer
- Thiết kế API/backend không phân biệt rõ request đọc dữ liệu và request ghi dữ liệu

- Sử dụng phương thức GET cho các thao tác thay đổi trạng thái hệ thống

Những thiếu sót này thường xuất phát từ việc ưu tiên chức năng và trải nghiệm người dùng hơn là các yêu cầu an toàn ngay từ giai đoạn thiết kế.

d) Cách nhận biết và đánh giá nguy cơ CSRF

Việc nhận biết nguy cơ CSRF có thể được thực hiện thông qua:

- Kiểm tra các chức năng quan trọng có sử dụng CSRF token hay không
- Phân tích luồng request trong quá trình đăng nhập và thao tác người dùng
- Thử gửi lại các request quan trọng từ domain bên ngoài
- Giám sát log backend để phát hiện các hành vi thao tác bất thường từ người dùng hợp lệ

Trong thực tế, CSRF thường khó phát hiện bằng các công cụ tự động nếu không kết hợp với phân tích logic nghiệp vụ.

e) Biện pháp phòng tránh và giảm thiểu CSRF

Để phòng chống CSRF cho website thương mại điện tử, các biện pháp sau thường được áp dụng:

- Triển khai CSRF Token ngẫu nhiên và duy nhất cho mỗi phiên hoặc mỗi request
- Sử dụng thuộc tính SameSite cho cookie phiên
- Kiểm tra chặt chẽ header Origin và Referer
- Chỉ sử dụng phương thức POST/PUT/DELETE cho các thao tác thay đổi trạng thái
- Kết hợp xác thực đa yếu tố (2FA) cho các thao tác nhạy cảm
- Ghi log và giám sát các hành vi thao tác bất thường thông qua hệ thống SIEM

Việc kết hợp nhiều cơ chế phòng vệ giúp giảm đáng kể nguy cơ bị khai thác CSRF trong các hệ thống thương mại điện tử hiện đại.

CSRF vẫn nằm trong danh sách các lỗ hổng phổ biến theo OWASP Top 10 và thường xuất hiện trong các hệ thống web chưa áp dụng đầy đủ các tiêu chuẩn an toàn hiện đại. Đối với các website thương mại điện tử, nơi người dùng duy trì trạng thái đăng nhập lâu dài, CSRF là mối đe dọa cần được ưu tiên kiểm soát song song với SQL Injection và XSS.

1.2.5. Rủi ro an toàn thông tin từ chatbot

Chatbot là thành phần ứng dụng sử dụng các kỹ thuật xử lý ngôn ngữ tự nhiên (NLP) và trí tuệ nhân tạo nhằm tương tác tự động với người dùng. Trong website thương mại điện tử, chatbot thường được sử dụng để hỗ trợ tư vấn sản phẩm, giải đáp thắc mắc, hướng dẫn đặt hàng và nâng cao trải nghiệm người dùng.

Tuy nhiên, việc chatbot trực tiếp tiếp nhận dữ liệu đầu vào từ người dùng và tương tác với các thành phần backend của hệ thống cũng làm phát sinh nhiều rủi ro về an toàn thông tin nếu không được thiết kế và kiểm soát chặt chẽ.

a) Các rủi ro an toàn thông tin phổ biến từ chatbot

Chatbot có thể trở thành một điểm tấn công tiềm năng do các nguyên nhân sau:

- Tiếp nhận và xử lý trực tiếp dữ liệu đầu vào từ người dùng
- Tích hợp với hệ thống backend, cơ sở dữ liệu hoặc API nội bộ
- Có quyền truy cập một phần chức năng nghiệp vụ của hệ thống
- Thiếu cơ chế kiểm soát và ghi log chi tiết cho các tương tác

Những đặc điểm này khiến chatbot có thể bị lợi dụng để thực hiện các hành vi tấn công gián tiếp vào hệ thống website thương mại điện tử.

b) Quá trình khai thác rủi ro chatbot theo các giai đoạn

Quá trình khai thác chatbot thường diễn ra theo một chuỗi các bước có hệ thống:

- Giai đoạn thăm dò:

Kẻ tấn công tương tác với chatbot bằng nhiều dạng câu hỏi khác nhau nhằm xác định phạm vi chức năng, cách chatbot xử lý dữ liệu đầu vào và các phản hồi bất thường của hệ thống.

- Giai đoạn khai thác:

Sau khi xác định được điểm yếu, kẻ tấn công gửi các nội dung đầu vào được thiết kế đặc biệt nhằm:

- Gây lỗi logic xử lý
- Lợi dụng chatbot để truy xuất thông tin không được phép
- Thực hiện các hành vi tấn công gián tiếp vào backend

- Giai đoạn mở rộng tác động:

Nếu chatbot được tích hợp sâu với hệ thống, kẻ tấn công có thể tiếp tục khai thác để mở rộng phạm vi ảnh hưởng, gây rò rỉ dữ liệu, thao túng chức năng hoặc ảnh hưởng đến hoạt động của website thương mại điện tử.

c) Ảnh hưởng của rủi ro chatbot đối với hệ thống

Việc khai thác các điểm yếu trong chatbot có thể dẫn đến nhiều hậu quả nghiêm trọng, bao gồm:

- Rò rỉ thông tin người dùng và dữ liệu nội bộ
- Bị lợi dụng để thực hiện các yêu cầu trái phép tới hệ thống backend
- Gây sai lệch thông tin tư vấn cho người dùng
- Làm suy giảm uy tín và độ tin cậy của website thương mại điện tử

Đối với doanh nghiệp, các rủi ro này không chỉ ảnh hưởng đến mặt kỹ thuật mà còn tác động trực tiếp đến trải nghiệm và niềm tin của khách hàng.

d) Nguyên nhân khiến chatbot dễ trở thành điểm yếu

Một số nguyên nhân phổ biến khiến chatbot trở thành rủi ro an toàn thông tin bao gồm:

- Thiếu kiểm soát chặt chẽ dữ liệu đầu vào từ người dùng
- Phân quyền truy cập backend không rõ ràng
- Thiếu cơ chế giới hạn và giám sát hành vi của chatbot
- Chưa áp dụng đầy đủ các biện pháp bảo mật cho API và dịch vụ liên quan
- Ghi log và giám sát chưa được chú trọng

e) Cách nhận biết và đánh giá rủi ro chatbot

Việc đánh giá rủi ro chatbot có thể được thực hiện thông qua:

- Phân tích luồng dữ liệu giữa chatbot và backend
- Kiểm tra các quyền truy cập mà chatbot được cấp
- Theo dõi các phản hồi bất thường trong quá trình tương tác
- Giám sát log các yêu cầu được gửi từ chatbot tới hệ thống

Việc kết hợp kiểm thử thủ công và giám sát tập trung giúp phát hiện sớm các nguy cơ tiềm ẩn từ chatbot.

f) Định hướng phòng tránh rủi ro chatbot

Để giảm thiểu rủi ro an toàn thông tin từ chatbot, các biện pháp sau thường được áp dụng:

- Kiểm soát và lọc dữ liệu đầu vào từ người dùng
- Giới hạn quyền truy cập của chatbot theo nguyên tắc đặc quyền tối thiểu
- Tách biệt chatbot khỏi các thành phần nhạy cảm của hệ thống

- Ghi log đầy đủ các tương tác và hành vi bất thường
- Kết hợp giám sát thông qua hệ thống SIEM

Rủi ro từ chatbot là một vấn đề ngày càng được quan tâm trong các hệ thống website thương mại điện tử hiện đại. Việc nhận diện và kiểm soát sớm các nguy cơ này là cơ sở quan trọng để xây dựng các giải pháp an toàn toàn diện, đặc biệt trong bối cảnh chatbot ngày càng được tích hợp sâu vào hoạt động kinh doanh trực tuyến.

1.3. Các thành phần an toàn

Trước các mối đe dọa an toàn thông tin ngày càng đa dạng và phức tạp đối với website thương mại điện tử như đã phân tích ở mục 1.2, việc triển khai các thành phần an toàn đóng vai trò then chốt trong việc nâng cao khả năng phòng thủ, phát hiện và ứng phó sự cố. Các thành phần an toàn không chỉ giúp ngăn chặn tấn công ngay từ đầu mà còn hỗ trợ giám sát, phân tích và giảm thiểu tác động khi hệ thống bị xâm nhập.

Trong hệ thống website thương mại điện tử, các thành phần an toàn thường được triển khai theo nhiều lớp khác nhau, tương ứng với các tầng mạng, ứng dụng và quản lý vận hành, nhằm đảm bảo nguyên tắc phòng thủ nhiều lớp.

1.3.1. Ứng dụng giao thức HTTPS

HTTPS (HyperText Transfer Protocol Secure) là phiên bản bảo mật của giao thức HTTP, trong đó dữ liệu trao đổi giữa trình duyệt người dùng và máy chủ được mã hóa thông qua giao thức SSL/TLS. Việc áp dụng HTTPS giúp đảm bảo tính bảo mật, toàn vẹn và xác thực trong quá trình truyền dữ liệu trên môi trường mạng.

Đối với website thương mại điện tử, HTTPS đóng vai trò đặc biệt quan trọng do hệ thống thường xuyên xử lý các thông tin nhạy cảm như thông tin đăng nhập, dữ liệu cá nhân và giao dịch thanh toán. Nếu không sử dụng HTTPS, dữ liệu có thể bị nghe lén, chỉnh sửa hoặc giả mạo trong quá trình truyền tải, gây rủi ro nghiêm trọng đến an toàn thông tin.

Ngoài ra, HTTPS còn giúp:

- Xác thực danh tính máy chủ, giảm nguy cơ tấn công giả mạo
- Bảo vệ dữ liệu khỏi các hình thức tấn công trung gian (Man-in-the-Middle)
- Nâng cao mức độ tin cậy của website đối với người dùng

Việc triển khai HTTPS hiện nay được xem là yêu cầu cơ bản và bắt buộc đối với các website thương mại điện tử nhằm đảm bảo an toàn thông tin trong quá trình hoạt động.

1.3.2. Xác thực hai yếu tố

Xác thực hai yếu tố là cơ chế bảo mật yêu cầu người dùng cung cấp hai yếu tố xác thực độc lập để chứng minh danh tính khi truy cập vào hệ thống. Thông thường, hai yếu tố này bao gồm:

- Thứ người dùng biết (mật khẩu)
- Thứ người dùng có (mã OTP, thiết bị xác thực, ứng dụng sinh mã)

Trong các hệ thống website thương mại điện tử, việc chỉ sử dụng mật khẩu để xác thực tiềm ẩn nhiều rủi ro, đặc biệt khi người dùng sử dụng mật khẩu yếu hoặc bị lộ thông tin đăng nhập. Xác thực hai yếu tố giúp giảm thiểu đáng kể nguy cơ bị chiếm quyền tài khoản ngay cả khi mật khẩu đã bị lộ.

Việc áp dụng 2FA mang lại các lợi ích chính:

- Tăng cường mức độ bảo vệ tài khoản người dùng
- Hạn chế tác động của các cuộc tấn công đánh cắp thông tin đăng nhập
- Nâng cao độ an toàn cho các thao tác quan trọng như thanh toán, thay đổi thông tin cá nhân

Do đó, xác thực hai yếu tố được xem là một trong những biện pháp an toàn quan trọng cần được áp dụng cho các website thương mại điện tử hiện đại.

1.3.3. Web Application Firewall

Web Application Firewall (WAF) là thành phần an toàn được triển khai ở phía trước ứng dụng web, có nhiệm vụ giám sát, phân tích và kiểm soát các yêu cầu HTTP/HTTPS trước khi chúng được chuyển đến máy chủ ứng dụng. Khác với firewall truyền thống chủ yếu kiểm soát lưu lượng ở tầng mạng, WAF tập trung bảo vệ tầng ứng dụng – nơi tồn tại nhiều lỗ hổng phổ biến của website thương mại điện tử.

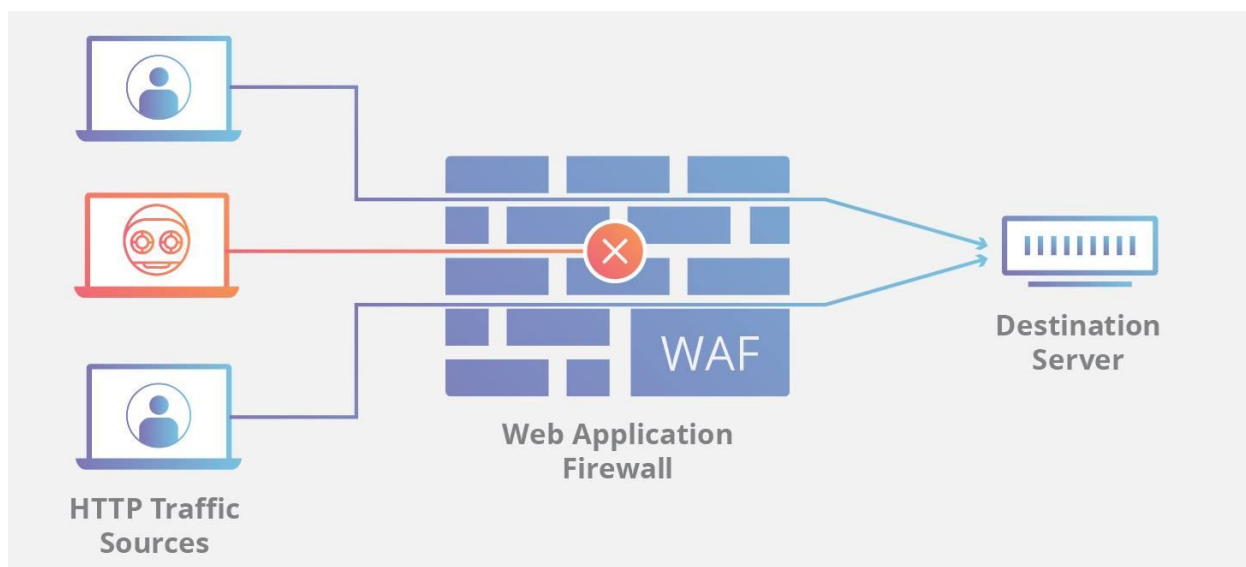
Trong bối cảnh hệ thống thương mại điện tử, WAF đóng vai trò đặc biệt quan trọng trong việc:

- Phát hiện và ngăn chặn các yêu cầu bất thường có dấu hiệu tấn công
- Bảo vệ các chức năng nghiệp vụ quan trọng như đăng nhập, tìm kiếm, thanh toán
- Giảm thiểu rủi ro khai thác các lỗ hổng XSS và SQL Injection

WAF hoạt động dựa trên các tập luật bảo mật, cho phép phân tích nội dung yêu cầu, tham số truy vấn và hành vi truy cập. Nhờ đó, các yêu cầu độc hại có thể bị chặn trước khi gây ảnh hưởng đến hệ thống phía sau. Ngoài chức năng phòng vệ,

WAF còn hỗ trợ ghi nhận và phân tích lưu lượng truy cập, cung cấp dữ liệu quan trọng cho công tác giám sát an toàn.

Tuy nhiên, hiệu quả của WAF phụ thuộc lớn vào việc cấu hình và cập nhật luật bảo mật. Nếu không được triển khai và vận hành đúng cách, WAF có thể bỏ sót các tấn công tinh vi hoặc gây ảnh hưởng đến trải nghiệm người dùng hợp lệ.



Hình 1.4 Chức năng của tường lửa ứng dụng web

a) Vị trí trong kiến trúc hệ thống

Web Application Firewall (WAF) được triển khai tại ranh giới giữa Internet và máy chủ ứng dụng web, đóng vai trò như lớp bảo vệ đầu tiên đối với tầng ứng dụng. Trong kiến trúc website thương mại điện tử, WAF thường nằm phía trước các dịch vụ xử lý nghiệp vụ quan trọng như đăng nhập, tìm kiếm sản phẩm và thanh toán.

Việc đặt WAF ở vị trí này cho phép kiểm soát toàn bộ luồng yêu cầu HTTP/HTTPS trước khi chúng tiếp cận logic nghiệp vụ của hệ thống.

b) Cơ chế kỹ thuật

Về mặt kỹ thuật, WAF hoạt động dựa trên việc phân tích nội dung và ngữ cảnh của từng yêu cầu web, bao gồm:

- Tham số truy vấn
- Dữ liệu biểu mẫu
- Header HTTP
- Hành vi truy cập theo thời gian

WAF sử dụng các tập luật để xác định các mẫu truy cập bất thường, từ đó đưa ra quyết định cho phép hoặc từ chối yêu cầu. Điểm khác biệt quan trọng của

WAF so với firewall truyền thống là khả năng hiểu và xử lý nội dung ở tầng ứng dụng.

c) Vai trò

Trong hệ thống website thương mại điện tử, WAF đóng vai trò chủ đạo trong việc:

- Giảm thiểu nguy cơ khai thác XSS thông qua kiểm soát dữ liệu đầu vào
- Ngăn chặn các yêu cầu có dấu hiệu SQL Injection
- Hạn chế các hành vi truy cập bất thường có thể dẫn đến tấn công DDoS tầng ứng dụng

Như vậy, WAF trực tiếp đối phó với các mối đe dọa đã phân tích ở mục 1.2

Bảng 1.1 Đối chiếu vai trò của WAF với các mối đe dọa

Mối đe dọa	Điểm tấn công	Vai trò của WAF	Mức độ hiệu quả
DDoS	Tầng ứng dụng	Lọc và giới hạn truy cập	Trung bình
XSS	Dữ liệu đầu vào	Chặn mã độc	Cao
SQL Injection	Truy vấn dữ liệu	Phát hiện truy vấn bất thường	Cao

d) Giới hạn kỹ thuật

Mặc dù có vai trò quan trọng, WAF không phải là giải pháp tuyệt đối. Các hạn chế phổ biến bao gồm:

- Khó phát hiện các tấn công tinh vi được ngụy trang như truy cập hợp lệ
- Phụ thuộc lớn vào chất lượng và cập nhật của tập luật
- Có thể gây ảnh hưởng đến hiệu năng hoặc trải nghiệm người dùng nếu cấu hình không phù hợp

Do đó, WAF cần được triển khai kết hợp với các thành phần an toàn khác.

1.3.4. IDPS

IDPS (Intrusion Detection and Prevention System) là hệ thống phát hiện và ngăn chặn xâm nhập, được sử dụng để giám sát các hoạt động bất thường trong hệ thống và kịp thời đưa ra cảnh báo hoặc biện pháp ngăn chặn. Trong website thương mại điện tử, IDPS thường được triển khai tại các điểm quan trọng trong kiến trúc mạng nhằm theo dõi lưu lượng và hành vi truy cập.

IDPS cho phép phân tích lưu lượng theo thời gian thực, từ đó phát hiện các dấu hiệu xâm nhập mà các cơ chế bảo vệ khác có thể không nhận ra. Trong môi

trường website thương mại điện tử, nơi lưu lượng truy cập lớn và đa dạng, IDPS giúp nâng cao khả năng phát hiện các hành vi bất thường tiềm ẩn rủi ro an toàn.

Tuy nhiên, IDPS có thể tạo ra số lượng lớn cảnh báo nếu không được tinh chỉnh phù hợp, gây khó khăn cho công tác vận hành và giám sát. Do đó, việc cấu hình và tích hợp IDPS với các hệ thống khác là yêu cầu quan trọng để đảm bảo hiệu quả.

a) Vị trí trong kiến trúc hệ thống

IDPS được triển khai tại các điểm giám sát trọng yếu trong kiến trúc mạng và hệ thống, nơi có thể quan sát được lưu lượng và hành vi truy cập nội bộ cũng như từ bên ngoài. Trong website thương mại điện tử, IDPS đóng vai trò như một lớp giám sát trung gian, giúp phát hiện sớm các hành vi tấn công mà WAF hoặc các cơ chế khác có thể bỏ sót.

b) Cơ chế kỹ thuật

IDPS hoạt động dựa trên việc phân tích lưu lượng và hành vi để phát hiện các dấu hiệu xâm nhập. Hệ thống này có khả năng:

- Nhận diện các mẫu tấn công đã biết
- Phát hiện các hành vi bất thường so với hoạt động bình thường
- Chủ động ngăn chặn hoặc cảnh báo khi phát hiện nguy cơ

Khác với WAF tập trung vào tầng ứng dụng, IDPS mở rộng phạm vi giám sát ra toàn bộ hệ thống.

c) Liên hệ trực tiếp với các mối đe dọa

IDPS đóng vai trò quan trọng trong việc:

- Phát hiện và giảm thiểu tấn công DDoS ở tầng mạng và hệ thống
- Nhận diện các hành vi dò quét, thăm dò lỗ hổng
- Phát hiện các hoạt động bất thường hậu khai thác sau XSS hoặc SQL Injection

Bảng 1.2 Vai trò của IDPS trong chuỗi phòng thủ

Giai đoạn tấn công	Vai trò của IDPS	Ý nghĩa
Thăm dò	Phát hiện dò quét	Cảnh báo sớm
Khai thác	Nhận diện hành vi bất thường	Hạn chế thiệt hại
Hậu khai thác	Giám sát truy cập nội bộ	Ngăn lan rộng

d) Giới hạn kỹ thuật của IDPS

IDPS có thể tạo ra số lượng lớn cảnh báo nếu không được tinh chỉnh phù hợp, gây áp lực cho đội ngũ vận hành. Ngoài ra, IDPS khó có thể phân tích sâu nội dung nghiệp vụ như WAF.

1.3.5. SIEM

SIEM (Security Information and Event Management) là hệ thống thu thập, phân tích và quản lý tập trung các sự kiện an toàn thông tin từ nhiều thành phần khác nhau trong hệ thống. Đối với website thương mại điện tử, SIEM đóng vai trò trung tâm trong việc giám sát an ninh và hỗ trợ ra quyết định trong quá trình vận hành.

SIEM cho phép:

- Thu thập log từ WAF, IDPS, máy chủ ứng dụng và cơ sở dữ liệu
- Phân tích và tương quan các sự kiện an ninh
- Phát hiện sớm các dấu hiệu tấn công hoặc xâm nhập kéo dài
- Hỗ trợ điều tra và đánh giá sự cố an toàn thông tin

Trong hệ thống TMĐT, nơi các thành phần vận hành phân tán và liên tục phát sinh sự kiện, SIEM giúp tập trung hóa công tác giám sát, giảm phụ thuộc vào việc theo dõi thủ công. Việc sử dụng SIEM giúp nâng cao khả năng phát hiện các cuộc tấn công phức hợp, trong đó nhiều kỹ thuật tấn công được kết hợp nhằm qua mặt các lớp bảo vệ đơn lẻ.

a) Vị trí trong kiến trúc vận hành

SIEM không trực tiếp tham gia xử lý lưu lượng mà đóng vai trò trung tâm trong kiến trúc vận hành an toàn. SIEM thu thập dữ liệu từ WAF, IDPS, máy chủ ứng dụng và cơ sở dữ liệu để phục vụ phân tích an ninh. Không giống WAF hay IDPS, SIEM không trực tiếp ngăn chặn tấn công mà hỗ trợ phát hiện các cuộc tấn công phức hợp và kéo dài.

b) Cơ chế kỹ thuật cốt lõi

SIEM hoạt động dựa trên:

- Thu thập log và sự kiện từ nhiều nguồn
- Chuẩn hóa và lưu trữ dữ liệu
- Phân tích tương quan giữa các sự kiện

Nhờ đó, SIEM có thể phát hiện các cuộc tấn công kéo dài hoặc phức hợp mà từng thành phần riêng lẻ khó nhận ra.

c) Liên hệ trực tiếp với các mối đe dọa

SIEM cho phép:

- Nhận diện chuỗi tấn công kết hợp DDoS, XSS và SQL Injection
- Phát hiện hành vi xâm nhập kéo dài trong hệ thống website thương mại điện tử
- Hỗ trợ điều tra và truy vết sự cố an toàn

Bảng 1.3 Vai trò của SIEM trong phát hiện tấn công phức hợp

Thành phần gửi log	Loại dữ liệu	Ý nghĩa phân tích
WAF	Log truy cập	Phát hiện tấn công web
IDPS	Cảnh báo xâm nhập	Nhận diện hành vi bất thường
Máy chủ	Log hệ thống	Phân tích hậu quả

d) Giới hạn kỹ thuật của SIEM

Hiệu quả của SIEM phụ thuộc lớn vào chất lượng dữ liệu đầu vào và kịch bản phân tích. Nếu không được cấu hình đúng, SIEM có thể trở thành hệ thống ghi log thụ động.

1.3.6. Quản trị bí mật và DevSecOps

Quản trị bí mật (Secrets Management) là quá trình quản lý, lưu trữ và bảo vệ các thông tin nhạy cảm của hệ thống như mật khẩu, khóa API, khóa mã hóa và thông tin truy cập cơ sở dữ liệu. Trong nhiều hệ thống, việc lưu trữ các bí mật này trực tiếp trong mã nguồn hoặc cấu hình không an toàn là nguyên nhân phổ biến dẫn đến rò rỉ thông tin.

DevSecOps là phương pháp tích hợp các yếu tố an toàn thông tin vào toàn bộ vòng đời phát triển phần mềm, từ khâu thiết kế, phát triển, triển khai đến vận hành. Cách tiếp cận này giúp đảm bảo an toàn không phải là bước bổ sung sau cùng mà là một phần xuyên suốt của hệ thống.

Trong bối cảnh website thương mại điện tử, việc kết hợp quản trị bí mật và DevSecOps giúp:

- Giảm nguy cơ lộ thông tin nhạy cảm trong quá trình phát triển và vận hành
- Nâng cao khả năng phát hiện và khắc phục sớm các lỗ hổng
- Đảm bảo các thay đổi hệ thống không làm suy giảm mức độ an toàn

DevSecOps được xem là xu hướng tất yếu trong việc xây dựng và vận hành các hệ thống web an toàn và bền vững.

1.3.7. Các thành phần hỗ trợ

Bên cạnh các thành phần an toàn chính như WAF, IDPS và SIEM, website thương mại điện tử còn cần đến các thành phần hỗ trợ nhằm hoàn thiện hệ thống

bảo mật tổng thể. Các thành phần này bao gồm các cơ chế hỗ trợ kiểm soát truy cập, bảo vệ dữ liệu và đảm bảo tính ổn định của hệ thống.

Các thành phần hỗ trợ có thể kể đến như:

- Cơ chế xác thực và phân quyền người dùng
- Sao lưu và khôi phục dữ liệu
- Cập nhật và vá lỗi hệ thống định kỳ
- Các công cụ hỗ trợ giám sát và kiểm thử an toàn

Mặc dù không trực tiếp ngăn chặn tấn công, các thành phần hỗ trợ đóng vai trò quan trọng trong việc giảm thiểu hậu quả và nâng cao khả năng phục hồi của website thương mại điện tử khi xảy ra sự cố an toàn thông tin.

1.4. Yêu cầu an toàn và các tiêu chí đánh giá

Để đảm bảo website thương mại điện tử hoạt động an toàn và ổn định, hệ thống cần đáp ứng một tập hợp các yêu cầu an toàn cơ bản. Những yêu cầu này là cơ sở để đánh giá mức độ an toàn của hệ thống cũng như hiệu quả của các giải pháp bảo mật được triển khai.

a) Yêu cầu an toàn đối với hệ thống

Các yêu cầu an toàn chính bao gồm:

- Tính bảo mật (Confidentiality): Đảm bảo thông tin người dùng và dữ liệu giao dịch không bị truy cập trái phép.
- Tính toàn vẹn (Integrity): Đảm bảo dữ liệu không bị thay đổi hoặc giả mạo trong quá trình xử lý và truyền tải.
- Tính sẵn sàng (Availability): Đảm bảo hệ thống hoạt động ổn định, hạn chế gián đoạn dịch vụ.
- Tính xác thực và kiểm soát truy cập: Đảm bảo chỉ các đối tượng hợp lệ mới được phép truy cập hệ thống.

b) Tiêu chí đánh giá mức độ an toàn

Dựa trên các yêu cầu an toàn, việc đánh giá hệ thống có thể được thực hiện thông qua các tiêu chí sau:

Bảng 1.4 Tiêu chí đánh giá mức độ an toàn

Tiêu chí	Nội dung đánh giá
Bảo mật truyền thông	Có áp dụng HTTPS
Xác thực người dùng	Có cơ chế 2FA
Quản lý truy cập	Phân quyền rõ ràng

Phát hiện tấn công	Có cơ chế giám sát, ghi log
Khả năng phản ứng	Hỗ trợ xử lý sự cố

Các tiêu chí này đóng vai trò là thước đo để đánh giá hiệu quả của các giải pháp an toàn được trình bày và triển khai trong các chương tiếp theo của báo cáo.

1.5. Cơ sở lý thuyết rút gọn

Từ các nội dung đã trình bày trong Chương 1, có thể rút ra một số cơ sở lý thuyết nền tảng làm tiền đề cho việc đánh giá và kiện toàn an toàn hệ thống website thương mại điện tử.

Trước hết, website thương mại điện tử là hệ thống thông tin có mức độ phức tạp cao, tích hợp nhiều thành phần như giao diện người dùng, xử lý nghiệp vụ, cơ sở dữ liệu và các dịch vụ thanh toán. Đặc điểm này khiến hệ thống phải đối mặt với nhiều mối đe dọa an toàn ở các tầng khác nhau, từ tầng mạng đến tầng ứng dụng và tầng dữ liệu.

Thứ hai, các mối đe dọa an toàn đối với website thương mại điện tử thường không tồn tại riêng lẻ mà có thể kết hợp thành các chuỗi tấn công phức hợp. Các hình thức tấn công phổ biến như DDoS, XSS và SQL Injection có thể được triển khai theo nhiều giai đoạn, từ thăm dò, khai thác cho đến hậu khai thác, gây ảnh hưởng nghiêm trọng đến tính sẵn sàng, toàn vẹn và bảo mật của hệ thống.

Thứ ba, việc đảm bảo an toàn cho website thương mại điện tử cần được tiếp cận theo hướng phòng thủ nhiều lớp. Các thành phần an toàn như Web Application Firewall, IDPS và SIEM đóng vai trò bổ trợ lẫn nhau, tương ứng với các tầng và giai đoạn khác nhau trong vòng đời tấn công. Không có một thành phần đơn lẻ nào có thể đảm bảo an toàn tuyệt đối cho hệ thống.

Cuối cùng, an toàn thông tin không chỉ là vấn đề kỹ thuật mà còn gắn liền với công tác vận hành và quản lý hệ thống. Việc giám sát liên tục, phân tích sự kiện an ninh và cải tiến các cơ chế bảo vệ là yêu cầu bắt buộc để duy trì mức độ an toàn phù hợp cho website thương mại điện tử trong bối cảnh các mối đe dọa ngày càng gia tăng.

Những cơ sở lý thuyết trên là nền tảng quan trọng cho việc đánh giá thực trạng an toàn và đề xuất các giải pháp kiện toàn hệ thống website thương mại điện tử trong các chương tiếp theo.

1.6. Kết luận chương 1

Chương 1 đã trình bày tổng quan về thực trạng phát triển của thương mại điện tử, các mối đe dọa an toàn điển hình đối với website thương mại điện tử và các

thành phần an toàn cơ bản trong hệ thống. Qua đó, có thể thấy rằng sự phát triển mạnh mẽ của thương mại điện tử kéo theo những yêu cầu ngày càng cao về đảm bảo an toàn thông tin.

Các mối đe dọa như tấn công từ chối dịch vụ, khai thác lỗ hổng ứng dụng và xâm nhập trái phép không chỉ gây thiệt hại về mặt kỹ thuật mà còn ảnh hưởng trực tiếp đến uy tín, hoạt động kinh doanh và niềm tin của người dùng đối với các hệ thống thương mại điện tử. Việc phân tích các mối đe dọa này cho thấy an toàn thông tin là một yếu tố không thể tách rời trong quá trình xây dựng và vận hành website thương mại điện tử.

Bên cạnh đó, chương này cũng đã làm rõ vai trò và ý nghĩa của các thành phần an toàn như Web Application Firewall, IDPS và SIEM trong việc hình thành một hệ thống phòng thủ nhiều lớp. Việc triển khai đồng bộ các thành phần này giúp nâng cao khả năng phòng ngừa, phát hiện và ứng phó với các sự cố an toàn thông tin.

Từ những phân tích trên, có thể khẳng định rằng việc đánh giá và kiện toàn an toàn cho hệ thống website thương mại điện tử là một yêu cầu cấp thiết và mang tính lâu dài. Đây chính là cơ sở để Chương 2 tập trung vào việc đánh giá thực trạng an toàn của hệ thống cụ thể và đề xuất các giải pháp phù hợp nhằm nâng cao mức độ an toàn cho website thương mại điện tử.

CHƯƠNG 2. GIẢI PHÁP AN TOÀN CHO WEBSITE THƯƠNG MẠI ĐIỆN TỬ

2.1. Giải pháp tại lớp ứng dụng

Lớp ứng dụng (Application Layer) là thành phần trung tâm trong kiến trúc website thương mại điện tử, nơi trực tiếp triển khai các chức năng nghiệp vụ như đăng nhập người dùng, quản lý sản phẩm, xử lý đơn hàng và thanh toán trực tuyến. Do đặc thù phải tiếp nhận và xử lý một lượng lớn dữ liệu đầu vào từ người dùng thông qua các giao thức web, lớp ứng dụng cũng là khu vực chịu nhiều rủi ro an toàn thông tin nhất trong toàn bộ hệ thống.

Khác với các lớp bảo vệ ở tầng mạng hoặc tầng hệ điều hành, các mối đe dọa tại lớp ứng dụng thường khai thác trực tiếp vào logic xử lý của chương trình, các sai sót trong kiểm soát dữ liệu đầu vào, cũng như cơ chế xác thực và phân quyền chưa chặt chẽ. Điều này khiến cho các cuộc tấn công như SQL Injection, Cross-Site Scripting (XSS) hay chiếm quyền truy cập tài khoản người dùng trở nên phổ biến và có mức độ ảnh hưởng nghiêm trọng đối với website thương mại điện tử.

Trong thực tế vận hành, nhiều hệ thống thương mại điện tử tập trung chủ yếu vào việc mở rộng chức năng và tối ưu trải nghiệm người dùng, trong khi các yếu tố an toàn ở lớp ứng dụng chưa được chú trọng đúng mức. Việc sử dụng các framework phát triển web, thư viện mã nguồn mở hoặc các đoạn mã tái sử dụng nhưng không được kiểm soát và cập nhật thường xuyên cũng làm gia tăng nguy cơ tồn tại các lỗ hổng bảo mật tiềm ẩn.

Giải pháp an toàn tại lớp ứng dụng vì vậy cần được xây dựng theo hướng phòng ngừa ngay từ giai đoạn thiết kế và phát triển, thay vì chỉ xử lý sự cố khi đã xảy ra tấn công. Cách tiếp cận này nhấn mạnh việc kết hợp giữa lập trình an toàn, kiểm soát truy cập chặt chẽ và xử lý dữ liệu đầu vào một cách có hệ thống, nhằm hạn chế khả năng kẻ tấn công khai thác các điểm yếu của ứng dụng.

Bên cạnh đó, các giải pháp tại lớp ứng dụng không thể hoạt động độc lập mà cần được triển khai đồng bộ với các cơ chế bảo vệ khác như Web Application Firewall và hệ thống giám sát an toàn. Tuy nhiên, việc củng cố lớp ứng dụng vẫn giữ vai trò nền tảng, bởi nếu bản thân ứng dụng tồn tại các lỗ hổng nghiêm trọng thì các lớp bảo vệ bên ngoài chỉ có thể giảm thiểu, chứ không thể loại bỏ hoàn toàn rủi ro.

2.1.1. Xác thực và phân quyền

a) Vai trò của xác thực và phân quyền trong website thương mại điện tử

Trong hệ thống website thương mại điện tử, xác thực (authentication) và phân quyền (authorization) là hai cơ chế nền tảng quyết định việc kiểm soát quyền truy cập của người dùng đối với các tài nguyên và chức năng của hệ thống. Xác thực giúp hệ thống xác định danh tính người dùng, trong khi phân quyền quy định phạm vi hành động mà người dùng đó được phép thực hiện sau khi đăng nhập thành công.

Do đặc thù phục vụ nhiều nhóm người dùng khác nhau như khách hàng, nhân viên vận hành và quản trị viên hệ thống, website thương mại điện tử thường có cấu trúc phân quyền phức tạp. Nếu cơ chế xác thực và phân quyền không được thiết kế và triển khai chặt chẽ, kẻ tấn công có thể lợi dụng các sai sót này để chiếm quyền tài khoản, truy cập trái phép vào dữ liệu nhạy cảm hoặc thực hiện các thao tác vượt quyền, gây ảnh hưởng nghiêm trọng đến hoạt động kinh doanh và uy tín của hệ thống.

b) Các rủi ro phổ biến liên quan đến xác thực và phân quyền

Trong thực tế, nhiều sự cố an toàn thông tin xuất phát từ các lỗ hổng trong cơ chế xác thực và phân quyền, bao gồm nhưng không giới hạn ở các vấn đề sau:

- Sử dụng mật khẩu yếu hoặc không có chính sách kiểm soát mật khẩu
- Không giới hạn số lần đăng nhập sai, tạo điều kiện cho tấn công brute force
- Quản lý phiên làm việc (session) không an toàn, dẫn đến nguy cơ chiếm quyền phiên
- Phân quyền không rõ ràng, cho phép người dùng truy cập các chức năng vượt quá vai trò được cấp

Đối với website thương mại điện tử, các rủi ro này có thể dẫn đến việc kẻ tấn công chiếm quyền tài khoản khách hàng để thực hiện giao dịch gian lận, hoặc nghiêm trọng hơn là truy cập vào tài khoản quản trị, từ đó kiểm soát toàn bộ hệ thống.

c) Giải pháp xác thực người dùng

Giải pháp xác thực người dùng cần được xây dựng dựa trên nguyên tắc đảm bảo tính chính xác của danh tính và hạn chế tối đa khả năng bị giả mạo. Trước hết, hệ thống cần áp dụng chính sách mật khẩu chặt chẽ, yêu cầu độ dài và độ phức tạp

phù hợp, đồng thời không lưu trữ mật khẩu dưới dạng văn bản thuần mà phải sử dụng các cơ chế bảo mật an toàn.

Bên cạnh đó, việc quản lý phiên làm việc cần được thực hiện cẩn trọng nhằm ngăn chặn nguy cơ đánh cắp phiên. Mỗi phiên đăng nhập phải được gán một định danh duy nhất, có thời gian hiệu lực cụ thể và bị hủy khi người dùng đăng xuất hoặc không hoạt động trong thời gian dài. Việc kiểm soát phiên giúp giảm thiểu khả năng kẻ tấn công lợi dụng phiên hợp lệ để truy cập trái phép vào hệ thống.

Ngoài ra, đối với các chức năng nhạy cảm như quản trị hệ thống hoặc thanh toán, việc tăng cường các lớp xác thực bổ sung là cần thiết để nâng cao mức độ an toàn tổng thể.

d) Giải pháp phân quyền và kiểm soát truy cập

Phân quyền trong website thương mại điện tử cần được triển khai dựa trên vai trò người dùng, đảm bảo mỗi vai trò chỉ được phép thực hiện các thao tác cần thiết cho chức năng của mình. Cách tiếp cận này giúp hạn chế mức độ ảnh hưởng trong trường hợp một tài khoản bị xâm nhập.

Việc kiểm soát phân quyền không chỉ dừng lại ở giao diện người dùng mà cần được thực hiện chặt chẽ ở phía máy chủ. Mọi yêu cầu truy cập đến các chức năng nghiệp vụ đều phải được kiểm tra quyền hạn tương ứng, nhằm tránh tình trạng người dùng lợi dụng việc thay đổi tham số hoặc truy cập trực tiếp vào các đường dẫn nội bộ để vượt quyền.

e) Hiệu quả của giải pháp đối với an toàn hệ thống

Việc triển khai đồng bộ các giải pháp xác thực và phân quyền mang lại nhiều lợi ích cho website thương mại điện tử, bao gồm:

- Giảm nguy cơ chiếm quyền tài khoản người dùng.
- Hạn chế khả năng truy cập trái phép vào dữ liệu và chức năng nhạy cảm.
- Tăng cường khả năng kiểm soát và truy vết hành vi người dùng trong hệ thống.

Bảng 2.1 Đánh giá mức độ an toàn trước và sau khi áp dụng giải pháp xác thực và phân quyền

Tiêu chí đánh giá	Trước khi áp dụng	Sau khi áp dụng
Nguy cơ chiếm quyền tài khoản	Cao	Thấp
Khả năng truy cập vượt quyền	Có	Hạn chế

Mức độ kiểm soát người dùng	Thấp	Cao
Độ tin cậy của hệ thống	Trung bình	Cao

f) Nhận xét

Có thể thấy rằng xác thực và phân quyền không chỉ là yêu cầu kỹ thuật cơ bản mà còn là yếu tố quyết định mức độ an toàn tổng thể của website thương mại điện tử. Việc đầu tư đúng mức cho cơ chế xác thực và phân quyền giúp hệ thống giảm thiểu đáng kể các rủi ro an toàn thông tin, đồng thời tạo nền tảng vững chắc cho việc triển khai các giải pháp bảo mật nâng cao ở các lớp tiếp theo.

2.1.2. Chống SQL Injection

a) Tổng quan về SQL Injection trong hệ thống thương mại điện tử

SQL Injection là một trong những hình thức tấn công phổ biến và nguy hiểm nhất đối với các website thương mại điện tử. Hình thức tấn công này khai thác các lỗ hổng trong quá trình xử lý dữ liệu đầu vào của ứng dụng, cho phép kẻ tấn công chèn các câu lệnh SQL độc hại vào truy vấn cơ sở dữ liệu. Khi truy vấn không được kiểm soát chặt chẽ, cơ sở dữ liệu sẽ thực thi các câu lệnh ngoài dự kiến, dẫn đến rò rỉ hoặc thao túng dữ liệu.

Đối với website thương mại điện tử, cơ sở dữ liệu thường lưu trữ các thông tin nhạy cảm như tài khoản người dùng, thông tin đơn hàng, dữ liệu thanh toán và thông tin vận hành nội bộ. Vì vậy, SQL Injection không chỉ ảnh hưởng đến tính bảo mật mà còn đe dọa trực tiếp đến hoạt động kinh doanh và uy tín của hệ thống.

b) Cách thức kẻ tấn công thực hiện SQL Injection

Trong kịch bản tấn công điển hình, kẻ tấn công tìm cách xác định các vị trí trong ứng dụng có tiếp nhận dữ liệu từ người dùng và đưa trực tiếp vào câu truy vấn SQL mà không qua kiểm tra hoặc xử lý an toàn. Các vị trí này thường bao gồm:

- Trường đăng nhập, tìm kiếm sản phẩm
- Tham số trên URL
- Biểu mẫu gửi dữ liệu (form submission)

Khi ứng dụng ghép chuỗi dữ liệu đầu vào với câu truy vấn SQL, kẻ tấn công có thể chèn thêm các toán tử logic hoặc câu lệnh SQL bổ sung nhằm thay đổi cấu trúc truy vấn ban đầu. Từ đó, chúng có thể vượt qua cơ chế xác thực, truy xuất dữ liệu trái phép hoặc thậm chí thay đổi nội dung cơ sở dữ liệu.

c) Hậu quả và mức độ ảnh hưởng đối với website thương mại điện tử

Hậu quả của SQL Injection đối với website thương mại điện tử thường rất nghiêm trọng và có phạm vi ảnh hưởng rộng. Các tác động tiêu biểu có thể kể đến như:

- Rò rỉ thông tin tài khoản người dùng và dữ liệu cá nhân
- Thay đổi hoặc xóa dữ liệu đơn hàng, gây sai lệch quá trình giao dịch
- Chiếm quyền truy cập vào hệ thống quản trị

Làm gián đoạn hoạt động của website, ảnh hưởng đến trải nghiệm khách hàng

Trong nhiều trường hợp, việc bị khai thác SQL Injection còn kéo theo các hệ quả pháp lý và chi phí khắc phục lớn, đặc biệt khi dữ liệu khách hàng bị lộ lọt.

d) Nguyên nhân dẫn đến lỗ hổng SQL Injection

Các lỗ hổng SQL Injection thường xuất phát từ nhiều nguyên nhân khác nhau, trong đó phổ biến nhất là:

- Thiếu kiểm soát và xác thực dữ liệu đầu vào
- Thiết kế truy vấn SQL theo cách ghép chuỗi trực tiếp
- Sử dụng tài khoản cơ sở dữ liệu có quyền quá cao
- Thiếu kiểm tra và đánh giá an toàn trong quá trình phát triển ứng dụng

Những nguyên nhân này thường xuất hiện trong các hệ thống được phát triển nhanh, thiếu quy trình kiểm thử bảo mật đầy đủ hoặc tái sử dụng mã nguồn không được rà soát kỹ lưỡng.

e) Giải pháp chống SQL Injection tại lớp ứng dụng

Giải pháp chống SQL Injection cần được triển khai theo hướng nhiều lớp, tập trung vào việc loại bỏ khả năng can thiệp vào cấu trúc truy vấn ngay từ lớp ứng dụng. Trước hết, ứng dụng cần đảm bảo rằng mọi dữ liệu đầu vào đều được kiểm tra chặt chẽ về kiểu dữ liệu, độ dài và định dạng trước khi sử dụng trong truy vấn.

Bên cạnh đó, việc xây dựng truy vấn cần tuân thủ các nguyên tắc lập trình an toàn, tránh việc ghép chuỗi dữ liệu đầu vào trực tiếp với câu lệnh SQL. Thay vào đó, các cơ chế ràng buộc tham số cần được áp dụng để đảm bảo dữ liệu đầu vào không thể thay đổi logic truy vấn.

Ngoài ra, tài khoản truy cập cơ sở dữ liệu của ứng dụng cần được giới hạn quyền ở mức tối thiểu, chỉ cho phép thực hiện các thao tác cần thiết. Điều này giúp giảm thiểu mức độ ảnh hưởng ngay cả khi kẻ tấn công khai thác thành công lỗ hổng SQL Injection.

f) Nhận biết và phát hiện nguy cơ SQL Injection

Việc nhận biết sớm nguy cơ SQL Injection đóng vai trò quan trọng trong việc bảo vệ website thương mại điện tử. Một số dấu hiệu có thể cho thấy hệ thống đang tồn tại lỗ hổng hoặc bị khai thác bao gồm:

- Ứng dụng phản hồi lỗi bất thường liên quan đến truy vấn cơ sở dữ liệu
- Kết quả truy vấn không đúng với logic nghiệp vụ
- Lưu lượng truy cập bất thường vào các chức năng tìm kiếm hoặc đăng nhập

Việc kết hợp kiểm tra định kỳ mã nguồn và giám sát hành vi truy cập giúp phát hiện sớm các dấu hiệu tấn công, từ đó có biện pháp xử lý kịp thời.

Bảng 2.2 Phân tích nguyên nhân – hậu quả – giải pháp đối với SQL Injection

Nguyên nhân	Hậu quả	Giải pháp đề xuất
Không kiểm soát đầu vào	Rò rỉ dữ liệu	Kiểm tra và xác thực dữ liệu
Ghép chuỗi SQL	Thao túng truy vấn	Truy vấn an toàn
Quyền DB quá cao	Mở rộng phạm vi tấn công	Giới hạn quyền truy cập
Thiếu kiểm thử	Khó phát hiện lỗ hổng	Đánh giá an toàn định kỳ

g) Đánh giá hiệu quả của giải pháp

Việc triển khai đồng bộ các giải pháp chống SQL Injection tại lớp ứng dụng giúp giảm đáng kể khả năng bị khai thác lỗ hổng, bảo vệ dữ liệu quan trọng và đảm bảo tính ổn định của website thương mại điện tử. Đây cũng là tiền đề quan trọng để hệ thống đáp ứng các yêu cầu về an toàn thông tin và tuân thủ các tiêu chuẩn bảo mật trong môi trường kinh doanh trực tuyến.

Bảng 2.3 So sánh tác động trước và sau khi áp dụng giải pháp

Tiêu chí	Trước khi áp dụng	Sau khi áp dụng
Nguy cơ SQL Injection	Cao	Thấp
Khả năng truy cập trái phép dữ liệu	Có	Hạn chế
Mức độ an toàn dữ liệu	Thấp	Cao

2.1.3. Chống XSS

a) Tổng quan về Cross-Site Scripting trong website thương mại điện tử

Cross-Site Scripting (XSS) là hình thức tấn công cho phép kẻ tấn công chèn và thực thi mã độc (thường là mã phía trình duyệt) trong ngữ cảnh của website hợp

lệ. Khác với SQL Injection vốn nhắm vào tầng cơ sở dữ liệu, XSS khai thác trực tiếp mối quan hệ tin cậy giữa trình duyệt người dùng và ứng dụng web.

Trong hệ thống thương mại điện tử, website thường hiển thị nhiều nội dung động do người dùng tạo ra như đánh giá sản phẩm, bình luận, thông tin hồ sơ cá nhân hoặc nội dung giỏ hàng. Nếu dữ liệu này không được xử lý an toàn trước khi hiển thị, kẻ tấn công có thể lợi dụng để chèn mã độc và thực thi trên trình duyệt của người dùng khác, từ đó gây ra các rủi ro nghiêm trọng liên quan đến chiếm quyền phiên và gian lận giao dịch.

b) Cách thức kẻ tấn công thực hiện tấn công XSS

Quá trình tấn công XSS thường bắt đầu từ việc kẻ tấn công xác định các vị trí trong ứng dụng cho phép nhập dữ liệu và sau đó hiển thị lại dữ liệu đó trên giao diện web. Khi dữ liệu đầu vào không được kiểm soát chặt chẽ, mã độc có thể được lưu trữ hoặc phản hồi trực tiếp về phía trình duyệt.

Khi người dùng truy cập vào trang web chứa nội dung đã bị chèn mã độc, trình duyệt sẽ thực thi đoạn mã này như thể nó là một phần hợp lệ của website. Từ góc nhìn của người dùng, quá trình này diễn ra hoàn toàn vô hình, khiến họ khó nhận biết rằng phiên làm việc của mình đang bị khai thác.

c) Hậu quả và mức độ ảnh hưởng của XSS đối với hệ thống thương mại điện tử

Tác động của XSS đối với website thương mại điện tử thường tập trung vào việc xâm phạm quyền kiểm soát phiên người dùng và dữ liệu giao dịch. Các hậu quả tiêu biểu bao gồm:

- Đánh cắp thông tin phiên đăng nhập của người dùng
- Giả mạo hành vi người dùng để thực hiện các thao tác trái phép
- Thay đổi nội dung hiển thị, gây mất uy tín cho website
- Hỗ trợ các hình thức tấn công kết hợp như lừa đảo hoặc chiếm quyền tài khoản

Trong môi trường thương mại điện tử, việc chiếm quyền phiên người dùng có thể dẫn đến việc đặt đơn hàng trái phép, thay đổi thông tin giao hàng hoặc truy cập vào dữ liệu cá nhân, gây tổn thất tài chính và làm suy giảm niềm tin của khách hàng.

d) Nguyên nhân dẫn đến lỗ hổng XSS

Các lỗ hổng XSS thường xuất phát từ việc ứng dụng không thực hiện đầy đủ các biện pháp xử lý dữ liệu đầu vào và đầu ra. Một số nguyên nhân phổ biến bao gồm:

- Không kiểm tra hoặc lọc dữ liệu do người dùng nhập vào
- Hiển thị trực tiếp dữ liệu đầu vào mà không xử lý an toàn
- Thiếu cơ chế kiểm soát nội dung động
- Thiết kế ứng dụng không tính đến các kịch bản tấn công phía trình duyệt

Trong nhiều trường hợp, lỗ hổng XSS tồn tại lâu dài do khó phát hiện trong quá trình kiểm thử chức năng thông thường, đặc biệt khi ứng dụng có nhiều luồng hiển thị dữ liệu phức tạp.

e) Giải pháp chống XSS tại lớp ứng dụng

Giải pháp chống XSS cần tập trung vào việc đảm bảo rằng dữ liệu do người dùng cung cấp không thể được trình duyệt thực thi dưới dạng mã. Trước hết, ứng dụng cần áp dụng các biện pháp kiểm soát dữ liệu đầu vào, loại bỏ hoặc làm vô hiệu các ký tự và cấu trúc có khả năng gây nguy hiểm.

Song song với đó, dữ liệu trước khi hiển thị ra giao diện người dùng cần được xử lý an toàn, đảm bảo rằng nội dung chỉ được hiển thị dưới dạng dữ liệu thuần, không mang khả năng thực thi. Việc này đặc biệt quan trọng đối với các khu vực hiển thị nội dung động như bình luận, đánh giá sản phẩm hoặc thông báo hệ thống.

Ngoài ra, ứng dụng cần hạn chế khả năng thực thi mã không cần thiết trong trình duyệt thông qua các cơ chế kiểm soát phía trình duyệt, từ đó giảm thiểu tác động ngay cả khi dữ liệu độc hại vượt qua được lớp kiểm soát đầu vào.

f) Nhận biết và phát hiện nguy cơ XSS

Việc phát hiện sớm các lỗ hổng XSS giúp hạn chế khả năng bị khai thác trên diện rộng. Một số dấu hiệu cho thấy hệ thống có thể tồn tại lỗ hổng XSS bao gồm:

- Nội dung hiển thị trên giao diện bị thay đổi bất thường
- Xuất hiện các hành vi không mong muốn khi người dùng truy cập trang
- Các phản hồi bất thường từ phía trình duyệt khi xử lý nội dung động

Kết hợp kiểm thử bảo mật và giám sát hành vi người dùng giúp nâng cao khả năng phát hiện và xử lý kịp thời các nguy cơ liên quan đến XSS.

Bảng 2.4 Phân tích lỗ hổng XSS trong website thương mại điện tử

Yếu tố	Mô tả
Điểm khai thác	Nội dung động do người dùng nhập
Đối tượng bị ảnh hưởng	Người dùng hợp lệ
Hậu quả chính	Chiếm quyền phiên, gian lận
Biện pháp phòng chống	Kiểm soát đầu vào, xử lý hiển thị

g) Đánh giá hiệu quả của giải pháp

Việc triển khai các giải pháp chống XSS tại lớp ứng dụng giúp bảo vệ trực tiếp người dùng cuối và duy trì mức độ tin cậy của website thương mại điện tử. Khi được áp dụng đồng bộ với các giải pháp xác thực, phân quyền và chống SQL Injection, hệ thống sẽ có khả năng chống chịu tốt hơn trước các hình thức tấn công phổ biến ở tầng ứng dụng.

2.2. Giải pháp an toàn cho Chatbot

Trong các hệ thống website thương mại điện tử hiện nay, chatbot không chỉ đóng vai trò hỗ trợ tư vấn mà còn tham gia vào quá trình truy xuất thông tin, xử lý yêu cầu và tương tác với các thành phần backend. Điều này khiến chatbot trở thành một bề mặt tấn công tiềm ẩn nếu không được thiết kế và bảo vệ đúng cách. Do đó, các giải pháp an toàn cho chatbot cần được triển khai có hệ thống, tập trung vào kiểm soát dữ liệu, phân quyền truy cập và giám sát hoạt động.

2.2.1. Kiểm soát dữ liệu đầu vào và logic xử lý của chatbot

Dữ liệu đầu vào của chatbot chủ yếu đến từ người dùng và mang tính phi cấu trúc, đa dạng về nội dung và hình thức. Kẻ tấn công có thể lợi dụng đặc điểm này để chèn các chuỗi dữ liệu bất thường nhằm gây lỗi logic xử lý, làm sai lệch hành vi của chatbot hoặc gián tiếp tác động đến hệ thống backend.

Giải pháp an toàn đặt ra là cần xây dựng cơ chế kiểm soát dữ liệu đầu vào theo nhiều lớp. Trước hết, dữ liệu người dùng cần được kiểm tra, lọc và chuẩn hóa trước khi chatbot tiến hành phân tích hoặc phản hồi. Việc này giúp loại bỏ các ký tự, cấu trúc hoặc nội dung không phù hợp với mục đích xử lý của chatbot.

Bên cạnh đó, logic xử lý của chatbot cần được thiết kế theo hướng tách biệt giữa phần xử lý ngôn ngữ và phần tương tác với hệ thống backend. Chatbot không nên chuyển trực tiếp dữ liệu thô từ người dùng tới các chức năng nghiệp vụ quan trọng, mà cần thông qua các lớp trung gian kiểm soát và xác thực.

Việc kiểm soát dữ liệu đầu vào và logic xử lý giúp:

- Hạn chế nguy cơ chatbot bị lợi dụng làm kênh trung gian tấn công
- Giảm thiểu lỗi phát sinh do dữ liệu bất thường
- Nâng cao độ ổn định và an toàn cho toàn bộ hệ thống

2.2.2. *Giới hạn quyền truy cập của chatbot đối với hệ thống backend*

Trong mô hình website thương mại điện tử, chatbot thường được cấp quyền truy cập tới một số tài nguyên nhằm phục vụ chức năng tư vấn và hỗ trợ người dùng. Tuy nhiên, nếu chatbot được cấp quyền quá rộng hoặc không được kiểm soát chặt chẽ, kẻ tấn công có thể lợi dụng chatbot để mở rộng phạm vi tác động đến hệ thống.

Giải pháp an toàn hiệu quả là áp dụng nguyên tắc đặc quyền tối thiểu, theo đó chatbot chỉ được phép thực hiện những thao tác thực sự cần thiết cho chức năng của mình. Các thao tác nhạy cảm như thay đổi dữ liệu người dùng, xử lý đơn hàng hoặc truy xuất thông tin quan trọng cần được tách biệt và yêu cầu các cơ chế xác thực bổ sung.

Ngoài ra, việc phân tách rõ ràng vai trò giữa chatbot và các thành phần backend giúp hạn chế khả năng leo thang đặc quyền trong trường hợp chatbot bị khai thác. Khi quyền truy cập của chatbot được giới hạn hợp lý, phạm vi ảnh hưởng của các sự cố an toàn cũng được thu hẹp đáng kể.

Giải pháp này mang lại các lợi ích:

- Giảm thiểu thiệt hại khi chatbot bị tấn công
- Ngăn chặn khả năng mở rộng quyền truy cập trái phép
- Tăng cường khả năng kiểm soát và quản lý hệ thống

2.2.3. *Ghi log và giám sát hoạt động chatbot thông qua hệ thống SIEM*

Bên cạnh các biện pháp phòng ngừa, việc giám sát và phát hiện sớm các hành vi bất thường liên quan đến chatbot đóng vai trò quan trọng trong bảo vệ hệ thống. Các tương tác giữa chatbot và người dùng, cũng như các request mà chatbot gửi tới backend, cần được ghi nhận đầy đủ và có hệ thống.

Việc tích hợp log của chatbot vào hệ thống SIEM cho phép tập trung phân tích các sự kiện an toàn, từ đó phát hiện các mẫu hành vi bất thường như tần suất truy cập bất thường, nội dung yêu cầu không hợp lệ hoặc các chuỗi tương tác có dấu hiệu khai thác.

Thông qua SIEM, hệ thống có thể:

- Phát hiện sớm các hành vi tấn công hoặc lạm dụng chatbot
- Hỗ trợ truy vết và điều tra sự cố an toàn

- Cung cấp dữ liệu phục vụ cải tiến các biện pháp phòng vệ

Giám sát chatbot không chỉ giúp phản ứng kịp thời trước các mối đe dọa mà còn góp phần nâng cao năng lực bảo mật tổng thể của website thương mại điện tử.

Nhận xét

Việc đảm bảo an toàn cho chatbot cần được xem là một phần không thể tách rời trong chiến lược bảo mật của website thương mại điện tử. Các giải pháp tập trung vào kiểm soát dữ liệu, giới hạn quyền truy cập và giám sát hoạt động giúp giảm thiểu rủi ro, đồng thời nâng cao tính ổn định và độ tin cậy của hệ thống trong quá trình vận hành.

2.3. Firewall và Web Application Firewall

2.3.1. Firewall trong hệ thống website thương mại điện tử

a) Vai trò của Firewall

Firewall là thiết bị hoặc phần mềm có chức năng kiểm soát lưu lượng mạng dựa trên các tập luật đã được thiết lập trước. Trong hệ thống thương mại điện tử, Firewall thường được triển khai tại ranh giới giữa mạng Internet và mạng nội bộ, nhằm:

- Ngăn chặn các truy cập trái phép từ bên ngoài
- Hạn chế các dịch vụ và cổng mạng không cần thiết
- Giảm thiểu nguy cơ tấn công ở tầng mạng

Firewall giúp đảm bảo rằng chỉ các luồng truy cập hợp lệ, phù hợp với chính sách an toàn mới được phép đi sâu vào hệ thống.

b) Các mối đe dọa Firewall có thể giảm thiểu

Thông qua việc kiểm soát lưu lượng ở tầng mạng, Firewall giúp hạn chế các mối đe dọa phổ biến như:

- Quét cổng và dò tìm dịch vụ
- Tấn công từ chối dịch vụ ở mức cơ bản
- Truy cập trái phép vào các cổng quản trị hoặc dịch vụ nội bộ

Đối với website thương mại điện tử, việc giảm tải các luồng truy cập độc hại ngay từ tầng mạng giúp hệ thống ổn định hơn và giảm áp lực cho các lớp bảo vệ phía sau.

c) Hạn chế của Firewall

Mặc dù đóng vai trò quan trọng, Firewall truyền thống chủ yếu hoạt động dựa trên thông tin tầng mạng và tầng giao vận, do đó không thể phân tích sâu nội

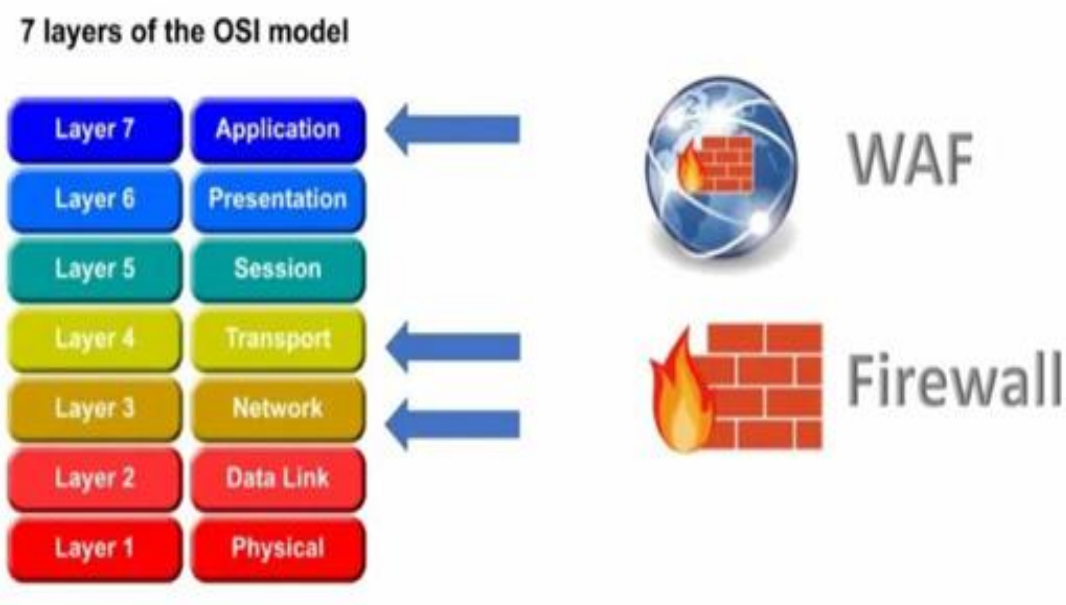
dung các yêu cầu HTTP/HTTPS. Điều này khiến Firewall khó có khả năng phát hiện và ngăn chặn các hình thức tấn công tinh vi ở tầng ứng dụng như SQL Injection hay XSS.

2.3.2. Kết hợp Firewall và WAF trong mô hình phòng thủ nhiều lớp

Việc triển khai Firewall và WAF cần được thực hiện theo mô hình phòng thủ nhiều lớp nhằm phát huy tối đa hiệu quả của từng thành phần. Firewall đảm nhiệm vai trò lọc và kiểm soát lưu lượng tổng thể, trong khi WAF tập trung bảo vệ chi tiết các yêu cầu web.

Sự kết hợp này giúp:

- Giảm tải cho lớp ứng dụng
- Hạn chế khả năng tiếp cận của các cuộc tấn công tự động
- Nâng cao khả năng phát hiện sớm các hành vi bất thường



Hình 2.1 Ứng dụng của Firewall và WAF

Bảng 2.5 So sánh Firewall và Web Application Firewall

Tiêu chí	Firewall	Web Application Firewall
Tầng bảo vệ	Mạng/Giao vận	Ứng dụng
Phân tích HTTP/HTTPS	Không	Có
Ngăn chặn SQL Injection	Không hiệu quả	Hiệu quả

Ngăn chặn XSS	Không	Có
Vai trò chính	Kiểm soát truy cập	Bảo vệ ứng dụng web

Bảng 2.6 Hiệu quả bảo vệ khi kết hợp Firewall và WAF

Tiêu chí đánh giá	Chỉ Firewall	Firewall + WAF
Nguy cơ tấn công web	Cao	Thấp
Khả năng bảo vệ ứng dụng	Hạn chế	Cao
Độ ổn định hệ thống	Trung bình	Cao
Mức độ an toàn tổng thể	Trung bình	Cao

2.3.3. Nhận xét

Firewall và Web Application Firewall không phải là các giải pháp thay thế lẫn nhau mà mang tính bổ trợ trong kiến trúc an toàn của website thương mại điện tử. Việc triển khai đồng bộ hai thành phần này giúp xây dựng lớp phòng thủ vững chắc, giảm thiểu đáng kể nguy cơ tấn công từ bên ngoài và tạo điều kiện cho các giải pháp giám sát, phân tích an toàn hoạt động hiệu quả hơn.

2.4. SIEM

Trong hệ thống website thương mại điện tử, các giải pháp phòng thủ như Firewall, WAF và các cơ chế an toàn tại lớp ứng dụng chỉ có thể ngăn chặn một phần các mối đe dọa. Trên thực tế, không có hệ thống nào đảm bảo an toàn tuyệt đối, do đó việc giám sát, phát hiện sớm và phản ứng kịp thời trước các sự cố an toàn là yêu cầu bắt buộc. SIEM ra đời nhằm đáp ứng nhu cầu này bằng cách tập trung hóa việc thu thập, phân tích và quản lý các sự kiện an ninh trong toàn bộ hệ thống.

- Khái niệm và vai trò của SIEM trong website thương mại điện tử

SIEM là hệ thống kết hợp giữa quản lý thông tin an ninh và quản lý sự kiện an ninh, cho phép thu thập log và dữ liệu sự kiện từ nhiều thành phần khác nhau trong hệ thống, sau đó thực hiện phân tích, tương quan và cảnh báo khi phát hiện các hành vi bất thường.

Đối với website thương mại điện tử, SIEM đóng vai trò trung tâm trong việc:

- Theo dõi hoạt động truy cập của người dùng.
- Giám sát các sự kiện an toàn phát sinh từ Firewall, WAF và máy chủ ứng dụng.
- Hỗ trợ phát hiện các cuộc tấn công phức hợp và kéo dài.

Nhờ khả năng tổng hợp dữ liệu từ nhiều nguồn, SIEM giúp quản trị viên có cái nhìn toàn diện về trạng thái an toàn của hệ thống thay vì chỉ theo dõi từng thành phần riêng lẻ.

- Các nguồn dữ liệu và sự kiện trong hệ thống SIEM

Trong môi trường website thương mại điện tử, SIEM cần thu thập dữ liệu từ nhiều nguồn khác nhau để đảm bảo khả năng phân tích chính xác. Các nguồn dữ liệu này bao gồm:

- Log truy cập và lỗi từ máy chủ ứng dụng.
- Log từ Firewall và Web Application Firewall.
- Log xác thực và phân quyền người dùng.
- Log truy cập cơ sở dữ liệu và hệ thống.

Việc tập trung hóa các nguồn dữ liệu giúp SIEM phát hiện các mối liên hệ giữa các sự kiện tưởng chừng như rời rạc, từ đó nhận diện các kịch bản tấn công phức tạp mà từng thành phần riêng lẻ khó có thể phát hiện.

- Cơ chế phân tích và tương quan sự kiện

Một trong những điểm mạnh cốt lõi của SIEM là khả năng phân tích và tương quan sự kiện an ninh. Thay vì chỉ ghi nhận các sự kiện đơn lẻ, SIEM xây dựng các quy tắc và mô hình để nhận diện hành vi bất thường dựa trên chuỗi sự kiện xảy ra theo thời gian.

Ví dụ, trong website thương mại điện tử, việc một tài khoản người dùng liên tục đăng nhập thất bại, sau đó truy cập các chức năng nhạy cảm và phát sinh truy vấn bất thường tới cơ sở dữ liệu có thể là dấu hiệu của một cuộc tấn công có chủ đích. SIEM cho phép phát hiện các kịch bản này thông qua việc kết hợp dữ liệu từ nhiều nguồn khác nhau.

- Vai trò của SIEM trong phát hiện và ứng phó sự cố

Ngoài khả năng phát hiện, SIEM còn hỗ trợ quá trình ứng phó sự cố an toàn thông tin. Khi phát hiện sự kiện bất thường, hệ thống có thể:

- Gửi cảnh báo đến quản trị viên
- Ghi nhận chi tiết sự kiện phục vụ điều tra
- Hỗ trợ truy vết nguồn gốc và phạm vi ảnh hưởng của sự cố

Đối với website thương mại điện tử, khả năng phản ứng nhanh giúp hạn chế thiệt hại, giảm thời gian gián đoạn dịch vụ và bảo vệ dữ liệu khách hàng.

- Lợi ích của việc triển khai SIEM cho website thương mại điện tử

Việc triển khai SIEM mang lại nhiều lợi ích thiết thực cho hệ thống thương mại điện tử, bao gồm:

- Nâng cao khả năng giám sát an toàn theo thời gian thực
- Phát hiện sớm các cuộc tấn công phức hợp
- Hỗ trợ phân tích nguyên nhân và đánh giá mức độ ảnh hưởng
- Tăng cường khả năng tuân thủ các yêu cầu về an toàn thông tin

SIEM không chỉ là công cụ kỹ thuật mà còn đóng vai trò quan trọng trong công tác quản lý và vận hành an toàn hệ thống.

Bảng 2.7 Các nguồn log và vai trò trong hệ thống SIEM

Nguồn log	Nội dung chính	Vai trò trong SIEM
Máy chủ ứng dụng	Truy cập, lỗi hệ thống	Phát hiện hành vi bất thường
Firewall	Lưu lượng mạng	Nhận diện truy cập trái phép
WAF	Yêu cầu HTTP/HTTPS	Phát hiện tấn công web
Hệ thống xác thực	Đăng nhập, phân quyền	Phát hiện chiếm quyền

Bảng 2.8 Hiệu quả giám sát an toàn trước và sau khi triển khai SIEM

Tiêu chí đánh giá	Trước khi có SIEM	Sau khi có SIEM
Khả năng phát hiện tấn công	Thấp	Cao
Thời gian phản ứng sự cố	Dài	Ngắn
Mức độ kiểm soát hệ thống	Phân tán	Tập trung
Hiệu quả điều tra sự cố	Hạn chế	Cao

⇒ **Nhận xét**

SIEM là thành phần không thể thiếu trong kiến trúc an toàn của website thương mại điện tử hiện đại. Khi được triển khai kết hợp với các giải pháp phòng thủ ở lớp ứng dụng và lớp biên, SIEM giúp hệ thống không chỉ phòng ngừa mà còn chủ động phát hiện và ứng phó với các mối đe dọa an toàn thông tin ngày càng tinh vi.

2.5. Luồng thực thi của hệ thống

Luồng thực thi của hệ thống an toàn mô tả toàn bộ quá trình xử lý một yêu cầu truy cập từ phía người dùng đến khi hệ thống phản hồi kết quả, đồng thời thể hiện cách các cơ chế bảo mật phối hợp với nhau trong suốt quá trình này. Đối với website thương mại điện tử, luồng thực thi không chỉ phản ánh hoạt động nghiệp vụ mà còn đóng vai trò quan trọng trong việc đảm bảo an toàn thông tin, đặc biệt trong môi trường có lưu lượng truy cập lớn và đa dạng đối tượng người dùng.

Luồng thực thi được xây dựng theo nguyên tắc phòng thủ nhiều lớp, trong đó mỗi thành phần an toàn thực hiện một chức năng cụ thể nhưng có mối liên hệ chặt chẽ với các thành phần khác. Việc tổ chức luồng xử lý rõ ràng giúp hệ thống hạn chế tối đa khả năng bỏ sót kiểm tra an toàn và tạo điều kiện thuận lợi cho công tác giám sát, phân tích sự cố.

2.5.1. Luồng xử lý yêu cầu truy cập và nghiệp vụ

Khi người dùng truy cập vào website thương mại điện tử, yêu cầu từ trình duyệt sẽ được gửi tới hệ thống thông qua giao thức HTTP/HTTPS. Ngay từ giai đoạn đầu, yêu cầu này được kiểm soát tại lớp biên thông qua Firewall nhằm loại bỏ các kết nối không hợp lệ hoặc có dấu hiệu truy cập trái phép.

Sau khi vượt qua Firewall, yêu cầu tiếp tục được chuyển tới Web Application Firewall để phân tích nội dung chi tiết. Tại đây, WAF thực hiện kiểm tra các tham số, cấu trúc yêu cầu và hành vi truy cập nhằm phát hiện các dấu hiệu tấn công ở tầng ứng dụng. Chỉ các yêu cầu được đánh giá là an toàn mới được phép chuyển tiếp vào lớp ứng dụng để xử lý nghiệp vụ.

Tại lớp ứng dụng, hệ thống thực hiện các cơ chế xác thực, phân quyền và xử lý dữ liệu theo logic nghiệp vụ đã được thiết kế. Việc kiểm soát truy cập tại giai đoạn này giúp đảm bảo rằng người dùng chỉ có thể thực hiện các chức năng phù hợp với vai trò được cấp, đồng thời hạn chế khả năng khai thác các lỗ hổng logic của ứng dụng.

2.5.2. Luồng giám sát và xử lý sự kiện an toàn

Song song với luồng xử lý nghiệp vụ, các sự kiện phát sinh trong quá trình hoạt động của hệ thống đều được ghi nhận và chuyển về hệ thống SIEM. Các sự kiện này bao gồm thông tin truy cập, hành vi người dùng, các yêu cầu bị từ chối cũng như các dấu hiệu bất thường được phát hiện bởi Firewall và WAF.

Hệ thống SIEM thực hiện phân tích và tương quan các sự kiện theo thời gian, từ đó phát hiện các kịch bản tấn công phức hợp hoặc các hành vi có nguy cơ gây mất an toàn cho hệ thống. Khi phát hiện dấu hiệu bất thường, SIEM có thể phát sinh cảnh báo để quản trị viên kịp thời đánh giá và đưa ra biện pháp xử lý phù hợp.

Việc tích hợp SIEM vào luồng thực thi giúp hệ thống không chỉ phản ứng bị động trước các sự cố an toàn mà còn chủ động trong việc giám sát và kiểm soát rủi ro, đặc biệt quan trọng đối với các website thương mại điện tử hoạt động liên tục.

2.5.3. Ý nghĩa của luồng thực thi đối với an toàn hệ thống

Luồng thực thi được thiết kế hợp lý giúp các giải pháp an toàn được triển khai trong Chương 2 phát huy hiệu quả tối đa. Việc kiểm soát yêu cầu ngay từ lớp biên, kết hợp với bảo vệ tại lớp ứng dụng và giám sát tập trung thông qua SIEM, tạo nên một chuỗi bảo vệ khép kín cho website thương mại điện tử.

Bên cạnh việc nâng cao mức độ an toàn, luồng thực thi rõ ràng còn hỗ trợ tốt cho công tác vận hành và bảo trì hệ thống. Khi xảy ra sự cố, quản trị viên có thể dễ dàng xác định vị trí phát sinh vấn đề, truy vết nguyên nhân và đánh giá mức độ ảnh hưởng, từ đó đưa ra phương án khắc phục hiệu quả.

Bảng 2.9 Tóm tắt luồng thực thi an toàn của hệ thống

Giai đoạn	Thành phần chính	Vai trò
Kiểm soát ban đầu	Firewall	Lọc truy cập
Phân tích yêu cầu	WAF	Ngăn chặn tấn công web
Xử lý nghiệp vụ	Ứng dụng	Xác thực, xử lý dữ liệu
Giám sát	SIEM	Phân tích, cảnh báo

Nhận xét

Việc xây dựng luồng thực thi an toàn là yếu tố then chốt giúp website thương mại điện tử duy trì hoạt động ổn định và an toàn trong môi trường mạng nhiều rủi ro. Luồng thực thi này tạo nền tảng cho các hoạt động triển khai và đánh giá hiệu quả giải pháp an toàn sẽ được trình bày trong Chương 3.

2.6. Kết luận chương 2

Chương 2 đã tập trung phân tích và đề xuất các giải pháp an toàn cho website thương mại điện tử dựa trên những mối đe dọa và rủi ro đã được làm rõ trong Chương 1. Các giải pháp được xây dựng theo hướng tiếp cận tổng thể, kết hợp giữa phòng ngừa, phát hiện và ứng phó sự cố nhằm nâng cao mức độ an toàn cho hệ thống trong môi trường hoạt động thực tế.

Trọng tâm của chương là các giải pháp bảo vệ tại lớp ứng dụng, nơi trực tiếp xử lý dữ liệu người dùng và các chức năng nghiệp vụ quan trọng của website thương mại điện tử. Thông qua việc phân tích các cơ chế xác thực và phân quyền, phòng chống SQL Injection và Cross-Site Scripting, chương đã làm rõ vai trò nền tảng của việc đảm bảo an toàn ngay từ giai đoạn thiết kế và phát triển ứng dụng.

Bên cạnh đó, chương cũng đề cập đến vai trò của các giải pháp bảo vệ ở lớp biên như Firewall và Web Application Firewall trong việc kiểm soát và sàng lọc lưu lượng truy cập, hạn chế khả năng các cuộc tấn công tiếp cận trực tiếp tới lớp

ứng dụng. Việc triển khai các thành phần này theo mô hình phòng thủ nhiều lớp giúp hệ thống tăng khả năng chống chịu trước các mối đe dọa từ bên ngoài.

Ngoài các giải pháp phòng ngừa, chương 2 đã nhấn mạnh tầm quan trọng của việc giám sát và phát hiện sớm sự cố an toàn thông qua hệ thống SIEM. Giải pháp này giúp tập trung hóa việc thu thập và phân tích sự kiện an ninh, hỗ trợ quản trị viên trong công tác phát hiện, điều tra và ứng phó kịp thời với các hành vi bất thường trong hệ thống.

Cuối cùng, thông qua việc xây dựng luồng thực thi an toàn, chương đã thể hiện cách các giải pháp được tích hợp và phối hợp với nhau trong quá trình vận hành website thương mại điện tử. Luồng thực thi này không chỉ giúp đảm bảo an toàn thông tin mà còn tạo điều kiện thuận lợi cho việc đánh giá hiệu quả và triển khai thực nghiệm các giải pháp trong giai đoạn tiếp theo.

Những nội dung đã trình bày trong Chương 2 là cơ sở quan trọng để triển khai các kịch bản kiểm thử, đánh giá và hoàn thiện hệ thống an toàn cho website thương mại điện tử, sẽ được tiếp tục trình bày và phân tích chi tiết trong Chương 3.

CHƯƠNG 3. TRIỂN KHAI THỰC NGHIỆM VÀ ĐÁNH GIÁ

3.1. Mô hình hệ thống triển khai

Trong quá trình thực hiện đồ án, một mô hình hệ thống được triển khai nhằm phục vụ cho việc kiểm thử và đánh giá các giải pháp an toàn cho website thương mại điện tử. Mô hình được xây dựng trong môi trường mạng nội bộ, đảm bảo tính kiểm soát và phù hợp với mục tiêu thực nghiệm của đề tài.

Hệ thống triển khai bao gồm các thành phần chính sau:

- Máy chủ web:

Website thương mại điện tử được triển khai trên một máy tính chạy hệ điều hành Windows 11. Ứng dụng web hoạt động ở chế độ localhost và đảm nhiệm vai trò xử lý các chức năng nghiệp vụ của hệ thống. Máy chủ web là đối tượng chính được sử dụng để đánh giá mức độ an toàn trước các kịch bản kiểm thử.

- Tường lửa pfSense:

pfSense được triển khai làm thiết bị trung gian trong mạng LAN nội bộ. Thành phần này đảm nhiệm chức năng định tuyến và kiểm soát lưu lượng truy cập giữa các máy trong mạng và máy chủ web. Do website chỉ hoạt động ở chế độ localhost, pfSense đóng vai trò bắt buộc để các máy khác trong mạng nội bộ có thể truy cập và tương tác với hệ thống.

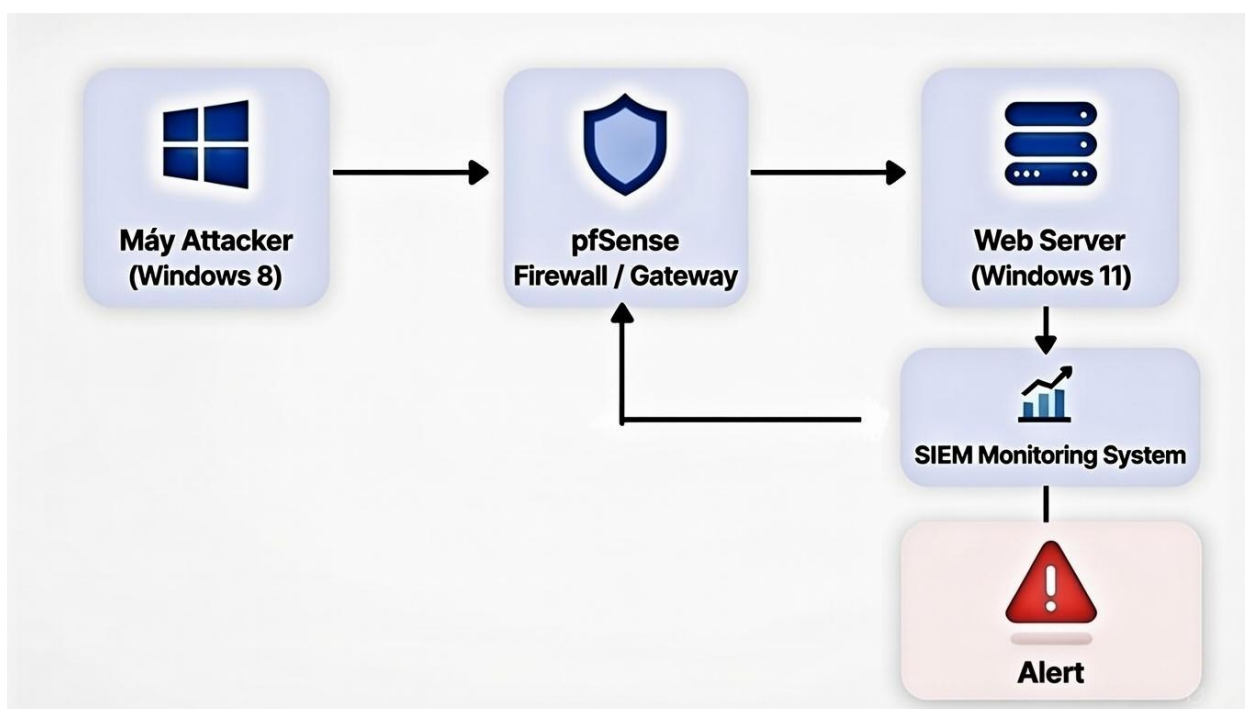
- Hệ thống SIEM:

Hệ thống SIEM được sử dụng để thu thập, lưu trữ và giám sát các bản ghi truy cập liên quan đến website. Các log được tạo ra từ backend của ứng dụng web và gửi về hệ thống SIEM thông qua cơ chế ghi log, phục vụ cho công tác phân tích và đánh giá an toàn trong quá trình kiểm thử.

- Máy giả lập attacker:

Một máy tính chạy hệ điều hành Windows 8 được sử dụng để thực hiện các yêu cầu truy cập thử nghiệm vào website thông qua tường lửa pfSense. Máy này đại diện cho các máy khách trong mạng nội bộ và được sử dụng để mô phỏng các hành vi truy cập trong các kịch bản kiểm thử an toàn.

➔ Trên cơ sở các thành phần nêu trên, mô hình hệ thống được xây dựng nhằm đảm bảo toàn bộ lưu lượng truy cập tới website đều đi qua tường lửa pfSense và được ghi nhận bởi hệ thống SIEM. Sơ đồ mô hình hệ thống thể hiện mối quan hệ và luồng truy cập giữa các thành phần, đóng vai trò là cơ sở cho việc xây dựng và thực hiện các kịch bản kiểm thử trong các mục tiếp theo của chương này.



Hình 3.1 Sơ đồ hệ thống triển khai thực nghiệm

3.2. Kịch bản kiểm thử

Phần này trình bày các kịch bản kiểm thử thực nghiệm đối với hệ thống đã triển khai nhằm đánh giá hiệu quả của các giải pháp an toàn được đề xuất. Các kịch bản bao gồm tấn công từ chối dịch vụ (DDoS), khai thác SQL Injection và Cross-Site Scripting (XSS). Mỗi kịch bản được mô tả theo mục tiêu kiểm thử, phương pháp thực hiện, kết quả quan sát và đánh giá mức độ an toàn trước và sau khi áp dụng giải pháp.

3.2.1. Kịch bản 1 (Cross-Site Scripting)

XSS cho phép attacker chèn script độc hại vào trang web, dẫn đến đánh cắp cookie/session hoặc lừa đảo người dùng trên website thương mại điện tử (ví dụ: giả mạo form thanh toán).

a. Môi trường thực hiện

Để thực hiện kịch bản này, hệ thống được thiết lập gồm các thành phần sau:

- Máy Tấn Công (Attacker):
 - Thiết bị: Máy tính chạy Windows 8 (hoặc máy ảo).
 - Công cụ: Trình duyệt web (Google Chrome / Firefox) để truy cập trang web và gửi mã độc.
 - Payload (Mã khai thác): Các đoạn mã JavaScript độc hại, ví dụ: `<script>alert('XSS')</script>`.

- Máy Chủ Mục Tiêu (Web Server):
 - Mã nguồn: app.py chạy trên nền tảng Python Flask.
 - Địa chỉ: http://<127.0.0.1>:5001.
 - Điểm yếu (Vulnerability): Endpoint /api/ratings (Chức năng đánh giá sản phẩm) nhận đầu vào từ người dùng là comment nhưng chưa lọc bỏ các thẻ HTML nguy hiểm trước khi lưu vào Database.
- Hệ thống Giám sát & Phòng thủ (SIEM):
 - Mã nguồn: app_groq.py chạy trên nền tảng Python Flask.
 - Địa chỉ: http://<127.0.0.1>:5000.
 - Chức năng: Lắng nghe log từ Web Server, phân tích chuỗi ký tự để phát hiện thẻ <script> hoặc các hàm nguy hiểm như alert(), onerror.

b. Tiến hành thực nghiệm

Quá trình thực nghiệm được chia làm 4 bước cụ thể như sau:

- Bước 1: Khởi tạo hệ thống Trên máy chủ, mở Terminal 1 và chạy SIEM: python app_groq.py

```

Microsoft Windows [Version 10.0.22000.2538]
(c) Microsoft Corporation. All rights reserved.

C:\Users\A>D:

D:\>cd AI-Driven-SIEM-Realtime-Operator-with-Groq-Integration
D:\AI-Driven-SIEM-Realtime-Operator-with-Groq-Integration>call venv\Scripts\activate

(venv) D:\AI-Driven-SIEM-Realtime-Operator-with-Groq-Integration>python app_groq.py
None of PyTorch, TensorFlow >= 2.0, or Flax have been found. Models won't be available and only tokenizers, configuration
n and file/data utilities can be used.
⚠ TensorFlow not available - skip loading ML model
* Serving Flask app 'app_groq'
* Debug mode: on
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://192.168.1.12:5000
Press CTRL+C to quit
* Restarting with stat
None of PyTorch, TensorFlow >= 2.0, or Flax have been found. Models won't be available and only tokenizers, configuration
n and file/data utilities can be used.
⚠ TensorFlow not available - skip loading ML model
* Debugger is active!
* Debugger PIN: 113-748-880
  
```

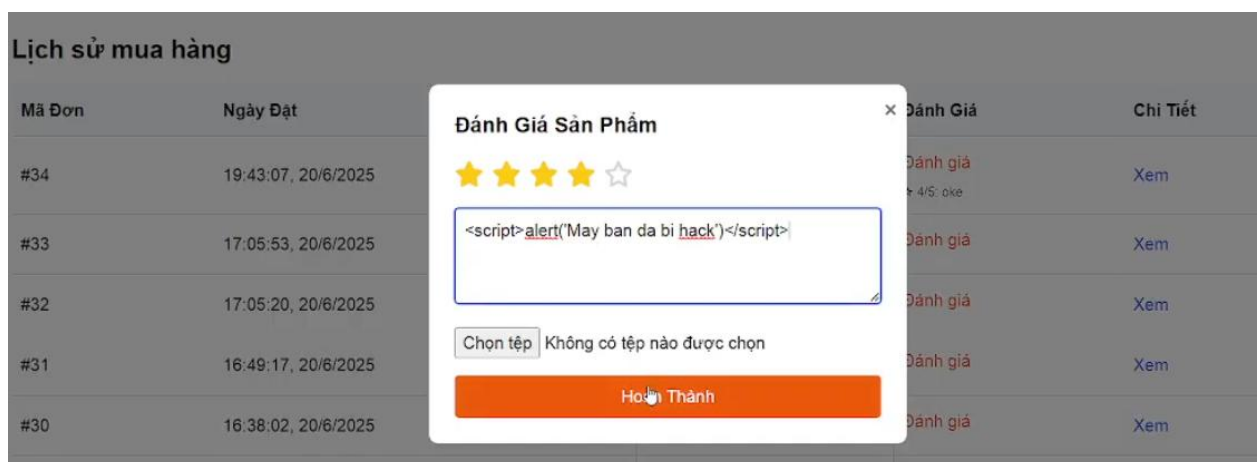
Hình 3.2 Khởi chạy SIEM trên máy chủ

- Trạng thái: SIEM lắng nghe tại cổng 5000, sẵn sàng nhận log.
- Trên máy chủ, mở Terminal 2 và chạy Web Server: python app.py

```
PS D:\sport-store-SIEM\sport-store-backend-SIEM> & C:/Users/A/AppData/Local/Programs/Python/Python313/python.exe d:/sport-store-SIEM/sport-store-backend-SIEM/app.py
* Serving Flask app 'app'
* Debug mode: on
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5001
* Running on http://192.168.1.12:5001
Press CTRL+C to quit
* Restarting with stat
* Debugger is active!
* Debugger PIN: 805-953-837
```

Hình 3.3 Chạy Web Server trên máy chủ

- Trạng thái: Web Server chạy tại cổng 5001, kết nối thành công với SQLite.
- Bước 2: Thăm dò và tấn công (từ phía Attacker). Hacker mở trình duyệt trên máy Windows 8, truy cập vào trang chi tiết của một sản phẩm bất kỳ (ví dụ: Giày Adidas Predator). Tại form "Viết đánh giá", Hacker nhập thông tin:
 1. Số sao: 4
 2. Nội dung bình luận (Payload): `<script>alert(May ban da bi hack!)</script>`
 3. Nhấn nút "Hoàn Thành".



Hình 3.4 Attacker thực hiện thăm dò và tấn công XSS

- Bước 3: Xử lý tại Web Server (Backend) app.py nhận yêu cầu POST tại `/api/ratings`. Và phản ứng của hệ thống giám sát SIEM
 1. Hệ thống thực hiện kiểm tra nội dung comment.
 2. Phát hiện: Code trong app.py phát hiện chuỗi `<script>` trong biến comment.

3. Hành động: Thay vì chỉ lưu vào DB, app.py gửi ngay một cảnh báo CRITICAL sang SIEM với nội dung: 🚨 PHÁT HIỆN TẤN CÔNG XSS:



Hình 3.5 Hệ thống phát hiện chuỗi <script> bất thường và gửi cảnh báo

- Bước 4: Ngăn chặn triệt để bằng cách vá lỗi (Remediation)
 - Sau khi SIEM đã cảnh báo, quản trị viên tiến hành vá lỗi trực tiếp tại mã nguồn Frontend để triệt tiêu lỗ hổng:
 1. Xác định vị trí lỗi: Tìm đoạn code xử lý hiển thị bình luận trong file HTML (purchase-history.html).
 2. Thực hiện sửa đổi: Trước khi sửa: `outputDiv.innerHTML = ...` (Cho phép thực thi mã).



Hình 3.6 Mã nguồn chứa lỗ hổng cho phép thực thi mã trong comment

3. Sau khi sửa: Thay đổi thành `outputDiv.textContent = ...`



Hình 3.7 Thực hiện vá lỗ hổng

- Giải thích kỹ thuật: Phương thức `textContent` thực hiện mã hóa đầu ra (Output Encoding). Khi đó, trình duyệt sẽ coi toàn bộ nội dung đoạn

<script>...</script> là một chuỗi văn bản thuần túy và hiển thị nó ra màn hình thay vì thực thi lệnh JavaScript bên trong.

⇒ **Kết luận thực nghiệm**

- Thành công: Hệ thống SIEM đã nhận diện chính xác hành vi chèn mã độc XSS ngay khi dữ liệu được gửi lên.
- Sau khi sửa đổi mã nguồn để vá lỗi XSS. Trình duyệt đã xem đoạn mã XSS như một đoạn văn bản thuần túy và không cho phép thực thi.
- Sau khi vá lỗi, nếu 1 attacker khác vẫn có ý định chèn đoạn mã XSS vào nhằm khai thác lỗ hổng dù đã được vá, hệ thống vẫn nhận diện đoạn mã là một hành vi tấn công và gửi cảnh báo lên SIEM.
- Minh chứng:
 1. Sau khi vá lỗ hổng, hệ thống xem đoạn mã XSS như một văn bản thuần túy và không cho phép thực thi đoạn mã.



Hình 3.8 Bằng chứng cho việc vá lỗ hổng XSS thành công

2. Nếu attacker vẫn có ý định tấn công XSS, hệ thống vẫn nhận diện văn bản dữ liệu đầu vào có định dạng là một đoạn script độc hại và gửi cảnh báo.

System Logs	
Zeit	Log
2025-12-30 04:11:24	🚨 PHÁT HIỆN TẤN CÔNG XSS:
2025-12-30 04:10:49	👤 Truy cập danh sách sản phẩm từ website bán hàng.
2025-12-30 04:09:59	🚨 PHÁT HIỆN TẤN CÔNG XSS:
2025-12-30 04:09:24	User đánh giá 4 sao. Nội dung: oke

Hình 3.9 Hệ thống vẫn gửi cảnh báo với các trường hợp có ý định xấu

3.2.2. Kịch bản 2 (DDoS)

Tấn công DDoS nhằm làm quá tải hệ thống bằng cách gửi một lượng lớn yêu cầu giả mạo, dẫn đến gián đoạn dịch vụ và ảnh hưởng đến trải nghiệm người dùng trên website thương mại điện tử. Kịch bản này kiểm tra khả năng phòng thủ của pfSense Firewall trước lưu lượng tấn công lớn.

a. Môi trường thực hiện

Để thực hiện kịch bản này, hệ thống sử dụng các thành phần sau:

- Máy Tấn Công (Attacker):
 - Thiết bị: Máy tính chạy Windows 8.
 - Công cụ: Sử dụng một đoạn mã python để gửi hàng loạt request HTTP liên tục trong thời gian ngắn.
 - Mục tiêu: Gửi hơn 30 yêu cầu trong vòng 10 giây tới các endpoint như /api/products.
- Máy Chủ Mục Tiêu (Web Server):
 - Mã nguồn: app.py chạy trên Port 5001.
 - Cơ chế phát hiện: Middleware detect_ddos sử dụng bộ đếm ip_counter để theo dõi số lượng request từ mỗi IP trong cửa sổ thời gian 10 giây.
- Hệ thống Giám sát & Phòng thủ (SIEM):
 - Mã nguồn: app_groq.py chạy trên Port 5000.
 - Chức năng: Nhận diện từ khóa "ddos" trong log để tự động trích xuất IP và thực hiện ngăn chặn.
 - Cơ chế Ngăn chặn: File blocklist.txt đóng vai trò là danh sách đen để pfSense thực hiện chặn đứng kết nối từ kẻ tấn công.

b. Tiến hành thực nghiệm

- Bước 1: Thiết lập ngưỡng giám sát
 1. Tại file app.py, middleware detect_ddos được cấu hình để gửi cảnh báo sang SIEM nếu một IP gửi vượt quá 30 yêu cầu trong 10 giây.

```
@app.before_request
def detect_ddos():
    # Ưu tiên lấy IP từ header nếu có (giả sử chạy sau proxy/nginx)
    ip = request.headers.get('X-Forwarded-For', request.remote_addr)
    print(f"🚀 Request từ IP: {ip}")

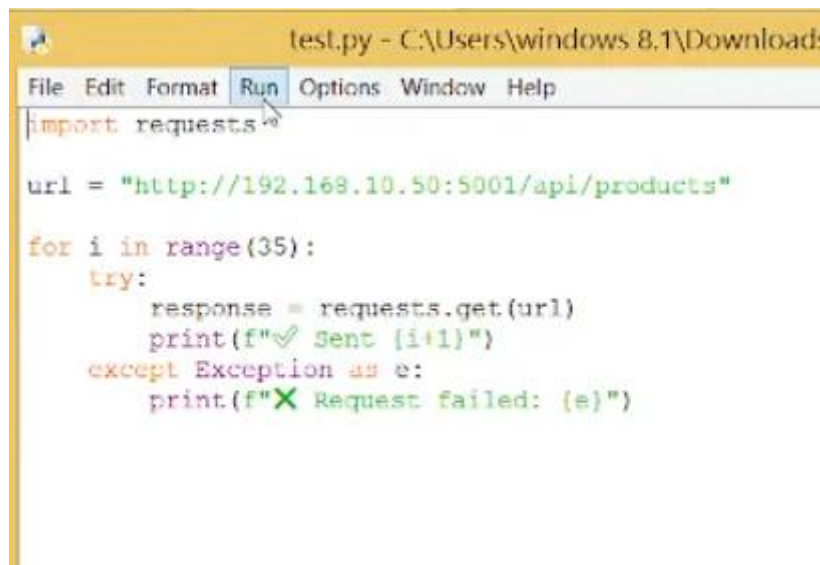
    now = time.time()
    ip_counter[ip] = [t for t in ip_counter[ip] if now - t < 10]
    ip_counter[ip].append(now)

    if len(ip_counter[ip]) > 30:
        send_log_to_siem(f"🚨 Phát hiện nghi ngờ DDoS từ IP {ip}: {len(ip_counter[ip])} y
```

Hình 3.10 Cấu hình phát hiện và gửi cảnh báo nghi ngờ DDoS

2. Khởi động Web Server và SIEM để bắt đầu quá trình giám sát.
- Bước 2: Thực hiện tấn công.
 - Từ máy Windows 8, Attacker sử dụng công cụ tấn công để "bắn" liên tục các request HTTP GET tới website.

- Ví dụ như đoạn mã sau đây: Gửi 35 yêu cầu liên tục đến web với địa chỉ “http://192.168.10.50:5001/api/products”.



```
test.py - C:\Users\windows 8.1\Downloads
File Edit Format Run Options Window Help
import requests

url = "http://192.168.10.50:5001/api/products"

for i in range(35):
    try:
        response = requests.get(url)
        print(f"✓ Sent {i+1}")
    except Exception as e:
        print(f"✗ Request failed: {e}")
```

Hình 3.11 Thực hiện gửi liên tục các request đến website

- Bước 3: Phát hiện tại Web Server. Hàm detect_ddos trong app.py liên tục cập nhật thời gian của từng request vào danh sách ip_counter[ip].
- Kích hoạt cảnh báo: Khi số lượng request từ IP máy Win 8 vượt ngưỡng 30, hàm send_log_to_siem sẽ được gọi để gửi bản tin log mức độ nguy hiểm: 🚨 Phát hiện nghi ngờ DDoS từ IP 192.168.10.100.

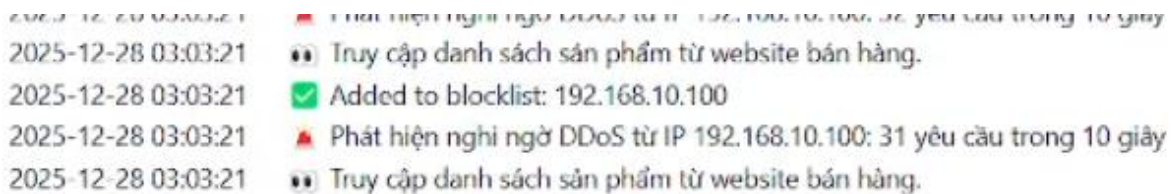
System Logs

Zeit	Log
2025-12-28 03:03:21	🔍 Truy cập danh sách sản phẩm từ website bán hàng.
2025-12-28 03:03:21	🚨 Phát hiện nghi ngờ DDoS từ IP 192.168.10.100: 35 yêu cầu trong 10 giây
2025-12-28 03:03:21	🔍 Truy cập danh sách sản phẩm từ website bán hàng.
2025-12-28 03:03:21	🚨 Phát hiện nghi ngờ DDoS từ IP 192.168.10.100: 34 yêu cầu trong 10 giây
2025-12-28 03:03:21	🔍 Truy cập danh sách sản phẩm từ website bán hàng.
2025-12-28 03:03:21	🚨 Phát hiện nghi ngờ DDoS từ IP 192.168.10.100: 33 yêu cầu trong 10 giây
2025-12-28 03:03:21	🔍 Truy cập danh sách sản phẩm từ website bán hàng.
2025-12-28 03:03:21	🚨 Phát hiện nghi ngờ DDoS từ IP 192.168.10.100: 32 yêu cầu trong 10 giây
2025-12-28 03:03:21	🔍 Truy cập danh sách sản phẩm từ website bán hàng.
2025-12-28 03:03:21	✅ Added to blocklist: 192.168.10.100
2025-12-28 03:03:21	🚨 Phát hiện nghi ngờ DDoS từ IP 192.168.10.100: 31 yêu cầu trong 10 giây
2025-12-28 03:03:21	🔍 Truy cập danh sách sản phẩm từ website bán hàng.
2025-12-28 03:03:21	🔍 Truy cập danh sách sản phẩm từ website bán hàng.

Hình 3.12 Hệ thống giám sát phát cảnh báo

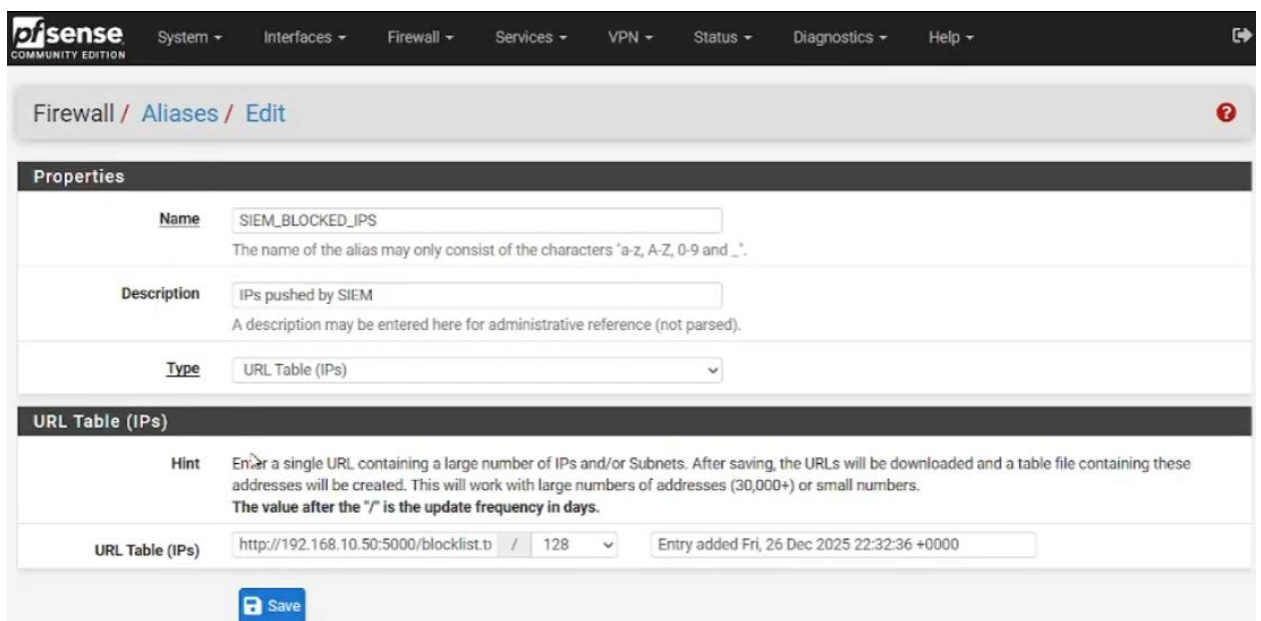
- Bước 4: Phản ứng của hệ thống phòng thủ.
 1. SIEM nhận được bản tin JSON từ cổng 5001 chứa thông tin về cuộc tấn công DDoS. Hàm receive_log trong SIEM phát hiện từ khóa "ddos" (không phân biệt hoa thường).

2. Kích hoạt hành động: Sử dụng hàm `extract_ip_from_message(msg)` hoặc lấy trực tiếp từ trường `ip` trong JSON để xác định địa chỉ IP nguồn tấn công.
3. Lưu thông báo cảnh báo vào database: 🚨 Phát hiện nghi ngờ DDoS từ IP 192.168.10.100.
4. Tự động gọi hàm `add_ip_to_blocklist(ip)` để ghi IP này vào file `blocklist.txt`.



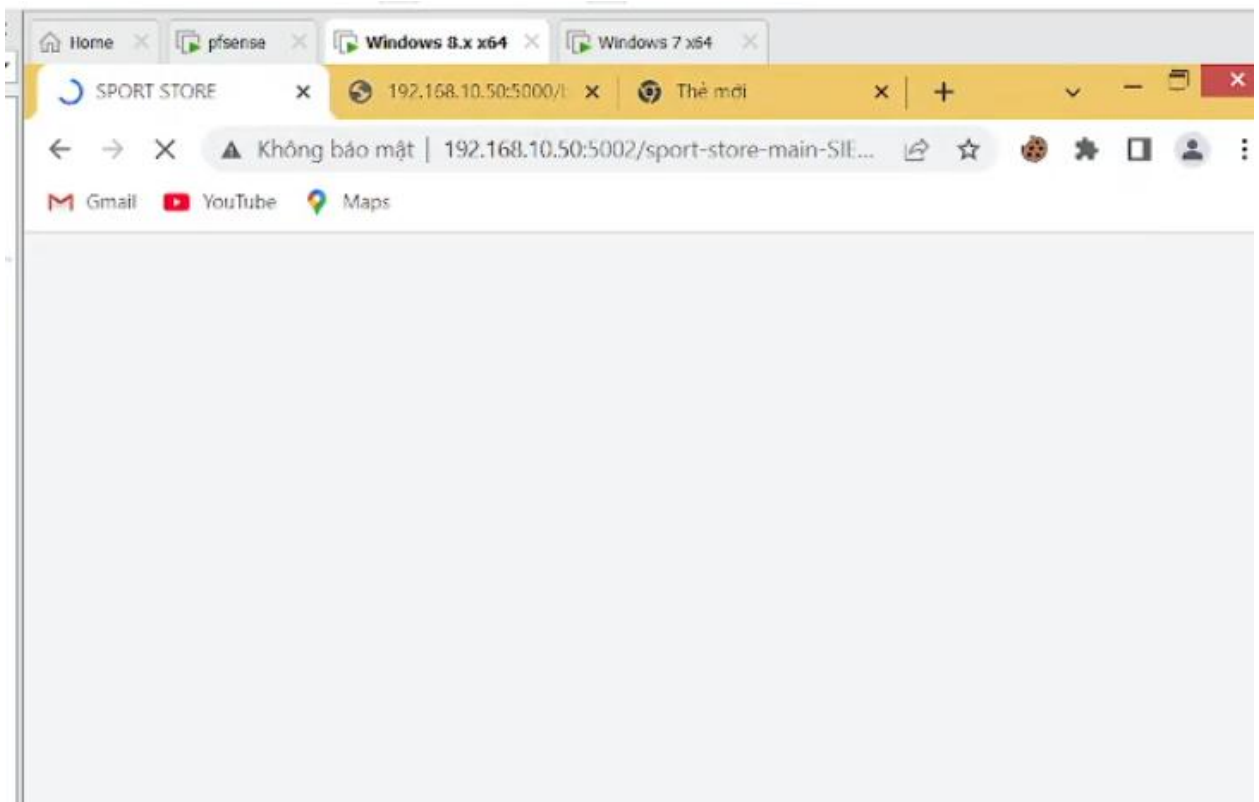
Hình 3.13 Tự động thêm địa chỉ IP vào danh sách chặn

- Bước 5: Ngăn chặn và Phục hồi (Mitigation)
 1. Chặn kết nối: pfSense (Firewall/Gateway) đọc file `blocklist.txt` và thực hiện chặn mọi gói tin từ IP của máy Win 8, bảo vệ tài nguyên của máy chủ Web.



Hình 3.14 Thực hiện ngăn chặn các IP trong danh sách

2. Kết quả: Địa chỉ IP của máy hacker(win8) đã bị chặn nên các request tiếp theo từ máy hacker sẽ bị từ chối tại lớp mạng, giúp CPU và RAM của máy chủ Web trở lại trạng thái ổn định.



Hình 3.15 Kết quả hacker không còn truy cập được website sau khi bị chặn

⇒ **Kết luận thực nghiệm:**

1. Độ chính xác: Hệ thống phát hiện đúng hành vi flood request dựa trên ngưỡng tần suất đã thiết lập.
2. Tính kịp thời: Quy trình từ khi phát hiện ở lớp ứng dụng đến khi SIEM ra lệnh chặn diễn ra gần như tức thì, giúp giảm thiểu tối đa tác động của cuộc tấn công DDoS.
3. Hiệu quả: Việc kết hợp logging tập trung (SIEM) và cơ chế chặn (blocklist) giúp hệ thống tự động phản ứng mà không cần sự can thiệp thủ công của quản trị viên.

3.2.3. Kịch bản 3 (SQL Injection)

SQL Injection là lỗ hổng phổ biến ở lớp ứng dụng, cho phép attacker chèn mã SQL độc hại vào các trường nhập liệu để truy cập hoặc sửa đổi cơ sở dữ liệu, chẳng hạn như đánh cắp thông tin khách hàng hoặc đơn hàng trên website thương mại điện tử.

a. Môi trường thực hiện

- Máy Tấn Công (Attacker):

- Thiết bị: Máy tính chạy Windows 8.
- Công cụ: Trình duyệt Web để thực hiện tấn công qua URL (GET request).

- Payload (Mã khai thác): Kỹ thuật UNION SELECT để trích xuất dữ liệu từ các bảng không được phép. Ví dụ: ' UNION SELECT 1, sqlite_version(), 3, 4, 5, 6--.
- Máy Chủ Mục Tiêu (Web Server):
 - Mã nguồn: app.py chạy Port 5001.
 - Cơ sở dữ liệu: SQLite (store.db).
- Điểm yếu (Vulnerability): Endpoint /api/vulnerable-search sử dụng nối chuỗi trực tiếp (f-string) để tạo câu lệnh SQL thay vì dùng tham số hóa (parameterized queries).
- Hệ thống Giám sát & Phòng thủ (SIEM):
 - Mã nguồn: app_groq.py chạy Port 5000.
 - Chức năng: Quét log từ Web Server để tìm các từ khóa SQL nguy hiểm như UNION SELECT, SQLITE_MASTER, ORDER BY.

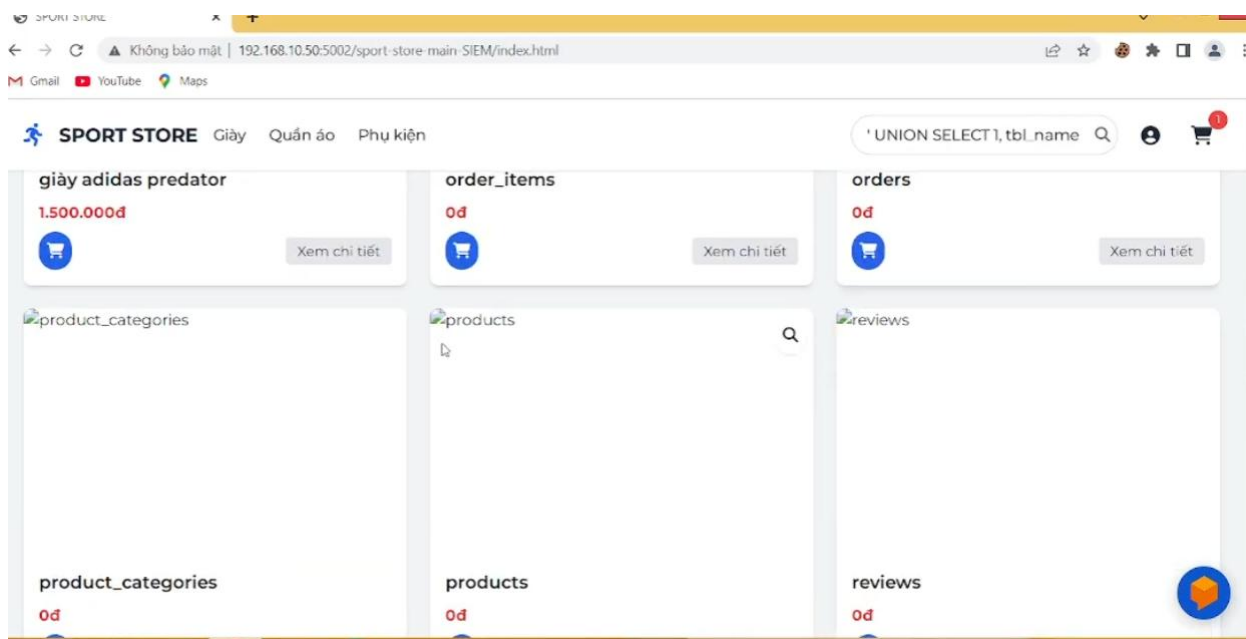
b. Tiến hành thực nghiệm

- Bước 1: Thăm dò lỗ hổng (Fingerprinting).
 1. Attacker từ máy Win 8 truy cập vào thanh tìm kiếm có lỗ hổng SQLi: `http://<IP_Server>:5001/api/vulnerable-search?q='`
 2. Kết quả: Web Server trả về lỗi SQL Syntax Error. Điều này xác nhận tham số q bị dính lỗi SQLi.
 3. Ghi nhận SIEM: SIEM nhận được log thô và ghi nhận yêu cầu tìm kiếm nghi vấn.
- Bước 2: Khai thác dữ liệu (Exploitation).
 1. Attacker gửi payload 'UNION SELECT 1, tbl_name, 0, 0, ','FROM sqlite master WHERE type='table'— để dò cấu trúc cơ sở dữ liệu SQLite.



Hình 3.16 Thực hiện khai thác cấu trúc CSDL

2. Kết quả trên Web: Tại vị trí tên sản phẩm, trình duyệt hiển thị các bảng tồn tại trong CSDL thay vì tên sản phẩm thông thường. Hacker đã đọc được thông tin nội bộ của máy chủ.



Hình 3.17 Kết quả hiển thị các bảng danh mục trong CSDL

- Bước 3: Phát hiện tấn công tại SIEM app_groq.py nhận log chứa chuỗi UNION SELECT.
- 1. Hàm receive_log đối chiếu với danh sách sql_keywords và xác định đây là tấn công mức độ nghiêm trọng. Kích hoạt phản ứng: In cảnh báo lên Console: 🦴 [SIEM CẢNH BÁO] PHÁT HIỆN TẤN CÔNG SQL INJECTION!.

System Logs

Zeit	Log
2025-12-30 07:48:44	✅ Added to blocklist: 192.168.10.100
2025-12-30 07:48:44	🔍 Vulnerable Search Request: q=' UNION SELECT 1, sqlite_version(), 3, 4, 5, 6--
2025-12-30 07:48:44	🦴 [SIEM ALERT] PHÁT HIỆN TẤN CÔNG SQL INJECTION
2025-12-30 07:48:29	🔄 Truy cập danh sách sản phẩm từ website bán hàng
2025-12-30 07:48:07	🔍 Vulnerable Search Request: q=balo
2025-12-30 07:48:06	🔄 Truy cập danh sách sản phẩm từ website bán hàng
2025-12-30 07:47:58	🔍 Vulnerable Search Request: q=giày

Hình 3.18 SIEM ghi nhận và phát cảnh báo, tự động thêm IP vào blocklist

- 2. Ghi log vào Dashboard SIEM: Added to blocklist: 192.168.10.100.
- Bước 4: Ngăn chặn tự động.

1. Hệ thống SIEM tự động gọi hàm `add_ip_to_blocklist` để ghi IP của Attacker vào file `blocklist.txt`.
2. Tường lửa pfSense (trong mô hình thực tế) sẽ đọc file này và chặn hoàn toàn kết nối từ IP đó đến Web Server.
3. Kết quả: Khi Attacker cố gắng tải lại trang (F5), kết nối sẽ bị từ chối hoặc không thể truy cập.

➔ Tương tự với các kết quả của kịch bản tấn công DDoS.

⇒ **Kết luận thực nghiệm**

1. Thành công: SIEM phát hiện chính xác hành vi khai thác UNION SELECT.
2. Hiệu quả: IP kẻ tấn công bị cô lập khỏi hệ thống ngay lập tức sau khi hành vi xâm nhập bị phát hiện.

3.3. Thu thập và trình bày kết quả

Dựa trên các kịch bản kiểm thử đã được thực hiện đối với hệ thống triển khai, bao gồm tấn công từ chối dịch vụ (DDoS), khai thác SQL Injection và Cross-Site Scripting (XSS), kết quả thực nghiệm cho thấy các giải pháp an toàn được đề xuất trong Chương 2 đã mang lại hiệu quả rõ rệt trong việc nâng cao mức độ an toàn cho website thương mại điện tử.

Đối với kịch bản DDoS, hệ thống trước khi áp dụng các biện pháp bảo vệ tại lớp biên có biểu hiện suy giảm hiệu năng khi lưu lượng truy cập tăng đột biến, ảnh hưởng trực tiếp đến khả năng cung cấp dịch vụ. Sau khi triển khai tường lửa pfSense với các chính sách kiểm soát truy cập phù hợp, lưu lượng bất thường được hạn chế đáng kể, giúp hệ thống duy trì trạng thái hoạt động ổn định hơn. Các sự kiện liên quan đến lưu lượng truy cập bất thường cũng được ghi nhận đầy đủ phục vụ cho công tác giám sát.

Trong kịch bản kiểm thử SQL Injection, kết quả thực nghiệm cho thấy hệ thống tồn tại nguy cơ lộ thông tin cấu trúc cơ sở dữ liệu khi chưa áp dụng các cơ chế xử lý truy vấn an toàn. Sau khi triển khai các biện pháp phòng chống tại lớp ứng dụng, các truy vấn bất thường không còn được thực thi, đồng thời các sự kiện liên quan được ghi nhận tại backend và gửi về hệ thống SIEM. Điều này cho thấy giải pháp kiểm soát dữ liệu đầu vào và xử lý truy vấn an toàn có vai trò quan trọng trong việc bảo vệ dữ liệu của hệ thống.

Đối với kịch bản Cross-Site Scripting, trước khi áp dụng giải pháp, dữ liệu đầu vào không được kiểm soát chặt chẽ có thể dẫn đến nguy cơ thực thi nội dung

không an toàn trên trình duyệt người dùng. Sau khi triển khai các biện pháp phòng chống XSS, hệ thống đã xử lý an toàn dữ liệu đầu vào và đầu ra, loại bỏ nguy cơ ảnh hưởng trực tiếp tới người dùng cuối. Các hành vi bất thường cũng được hệ thống ghi nhận và giám sát thông qua SIEM.

Bảng 3.1 Tổng hợp kết quả thực nghiệm

Kịch bản kiểm thử	Trạng thái trước khi áp dụng	Trạng thái sau khi áp dụng	Đánh giá
DDoS	Giảm hiệu năng, gián đoạn dịch vụ	Hoạt động ổn định hơn	Hiệu quả
SQL Injection	Nguy cơ lộ cấu trúc CSDL	Truy vấn bất thường bị chặn	Hiệu quả
XSS	Tiềm ẩn rủi ro phía người dùng	Nội dung hiển thị an toàn	Hiệu quả

Kết quả tổng hợp cho thấy các giải pháp an toàn đã được triển khai phù hợp với mô hình hệ thống và mang lại cải thiện rõ rệt về mức độ an toàn trong môi trường thực nghiệm.

3.4. Kết luận chương 3

Chương 3 đã trình bày quá trình triển khai thực nghiệm và đánh giá hiệu quả các giải pháp an toàn đối với website thương mại điện tử. Thông qua việc xây dựng mô hình hệ thống trong môi trường mạng nội bộ, kết hợp với tường lửa pfSense và hệ thống SIEM, đồ án đã tạo ra một nền tảng phù hợp để thực hiện các kịch bản kiểm thử an toàn.

Kết quả thực nghiệm cho thấy các giải pháp được đề xuất trong Chương 2 có tính khả thi và mang lại hiệu quả rõ rệt trong việc nâng cao mức độ an toàn cho hệ thống. Việc triển khai các cơ chế bảo vệ tại lớp biên và lớp ứng dụng không chỉ giúp hạn chế các nguy cơ tấn công phổ biến mà còn hỗ trợ tốt cho công tác giám sát và phát hiện sớm các hành vi bất thường thông qua hệ thống SIEM.

Bên cạnh những kết quả đạt được, chương này cũng cho thấy tầm quan trọng của việc kết hợp nhiều giải pháp an toàn trong một mô hình phòng thủ nhiều lớp. Điều này giúp website thương mại điện tử nâng cao khả năng chống chịu trước các mối đe dọa ngày càng phức tạp trong môi trường mạng hiện nay.

Những nội dung trình bày trong Chương 3 là cơ sở để đánh giá tổng thể hiệu quả của các giải pháp an toàn được đề xuất, đồng thời tạo tiền đề cho việc rút ra kết luận chung và định hướng phát triển trong các phần tiếp theo của đồ án.

KẾT LUẬN

1. Kết luận

Trong bối cảnh thương mại điện tử ngày càng phát triển mạnh mẽ, các website thương mại điện tử không chỉ đóng vai trò là nền tảng kinh doanh mà còn trở thành mục tiêu tấn công của nhiều mối đe dọa an toàn thông tin. Xuất phát từ thực tế đó, đồ án đã tập trung nghiên cứu, đánh giá và đề xuất các giải pháp nhằm nâng cao mức độ an toàn cho hệ thống website thương mại điện tử.

Thông qua việc phân tích tổng quan về thương mại điện tử và các mối đe dọa an toàn phổ biến trong Chương 1 đã làm rõ tính cấp thiết của việc đảm bảo an toàn thông tin cho website thương mại điện tử. Các hình thức tấn công điển hình như DDoS, SQL Injection và Cross-Site Scripting được phân tích nhằm chỉ ra những rủi ro tiềm ẩn đối với tính bảo mật, toàn vẹn và sẵn sàng của hệ thống.

Trên cơ sở đó, Chương 2 đã đề xuất các giải pháp an toàn phù hợp cho website thương mại điện tử theo hướng phòng thủ nhiều lớp. Các giải pháp được xây dựng tập trung vào bảo vệ tại lớp ứng dụng, lớp biên và giám sát tập trung thông qua hệ thống SIEM. Việc kết hợp nhiều cơ chế bảo mật giúp hạn chế nguy cơ bị khai thác lỗ hổng, đồng thời tăng khả năng phát hiện và ứng phó với các sự cố an toàn.

Chương 3 đã triển khai mô hình hệ thống thực nghiệm trong môi trường mạng nội bộ và thực hiện các kịch bản kiểm thử đối với các mối đe dọa điển hình. Kết quả thực nghiệm cho thấy các giải pháp an toàn được đề xuất có tính khả thi và mang lại hiệu quả rõ rệt trong việc nâng cao mức độ an toàn cho hệ thống. Hệ thống sau khi áp dụng giải pháp có khả năng kiểm soát tốt hơn các truy cập bất thường, hạn chế nguy cơ lộ thông tin và hỗ trợ hiệu quả cho công tác giám sát thông qua hệ thống SIEM.

Nhìn chung, đồ án đã đạt được các mục tiêu đề ra, góp phần làm rõ vai trò của các giải pháp an toàn trong việc bảo vệ website thương mại điện tử, đồng thời cung cấp một mô hình triển khai và đánh giá có thể tham khảo cho các hệ thống tương tự.

2. Hạn chế và hướng phát triển

Mặc dù đã đạt được những kết quả nhất định, đồ án vẫn còn tồn tại một số hạn chế. Mô hình triển khai được xây dựng trong phạm vi mạng nội bộ và mang tính mô phỏng, do đó chưa phản ánh đầy đủ các yếu tố phức tạp của môi trường triển khai thực tế quy mô lớn. Ngoài ra, các kịch bản kiểm thử mới chỉ tập trung

vào một số hình thức tấn công phổ biến, chưa bao quát hết các mối đe dọa nâng cao và các kỹ thuật tấn công phức tạp.

Trong thời gian tới, đề tài có thể được mở rộng theo các hướng phát triển sau:

- Mở rộng mô hình triển khai sang môi trường thực tế hoặc môi trường điện toán đám mây.
- Nghiên cứu và tích hợp thêm các giải pháp an toàn nâng cao như phát hiện xâm nhập dựa trên học máy.
- Mở rộng phạm vi kiểm thử với các hình thức tấn công phức tạp hơn và đánh giá hiệu quả hệ thống trong thời gian dài.
- Tối ưu hóa cơ chế giám sát và phân tích sự kiện an toàn nhằm nâng cao khả năng phát hiện sớm và phản ứng tự động trước các mối đe dọa.

TÀI LIỆU THAM KHẢO

- [1] Stefanus Eko Prasetyo, Haeruddin Haeruddin & Kelvin Ariesryo, “Website Security System from Denial of Service attacks, SQL Injection, Cross Site Scripting using Web Application Firewall”.
- [2] Abdelhakim Hannousse et al., “Twenty-two years since revealing cross-site scripting attacks: a systematic mapping and a comprehensive survey”.
- [3] Tài liệu ebook: “Triển khai an ninh trong Thương mại Điện tử,” doc.edu.vn.
- [4] Tài liệu “An ninh mạng và an toàn dữ liệu,” HCEM University.
- [5] Đề tài: “Triển khai an ninh trong Thương mại điện tử,” Ebook, doc.edu.vn.
- [6] Viettel Threat Intelligence, *Tình hình nguy cơ ATTT tại Việt Nam năm 2024*, 2025.
- [7] Website security và 3 hình thức tấn công web phổ biến nhất, VNIS (online), 2025.
- [8] Thương mại điện tử và an ninh mạng, ICTVietnam (online), 2025.
- [9] Hòa, N. S., Nhung, L. T. & Hải, Đ. T., “A Study on Security for Web-Based Applications,” Dalat University Journal of Science, vol. 7, no. 2, 2017.
- [10] SQLite Consortium, “SQLite Documentation,” 2023. [Online]. Available: <https://www.sqlite.org/docs.html>.

PHỤ LỤC

1. Mã chương trình thực hiện gửi log sang SIEM

```
def send_log_to_siem(message, level="INFO"):
    ip = request.headers.get('X-Forwarded-For',
request.remote_addr)
    if ip and "," in ip:
        ip = ip.split(",")[0].strip()

    payload = {
        "source": "E-COMMERCE",
        "level": level,
        "ip": ip,
        "method": request.method,
        "path": request.path,
        "query": dict(request.args),
        "message": message,
        "timestamp":
datetime.utcnow().isoformat(timespec="seconds")
    }
    try:
        requests.post(SIEM_URL, json=payload,
timeout=2)
    except Exception as e:
        print("⚠ Không gửi được log đến SIEM:", e)
```

2. Mã chương trình phát hiện tấn công DDoS

```
def detect_ddos():
    # Ưu tiên lấy IP từ header nếu có (giả sử
chạy sau proxy/nginx)
    ip = request.headers.get('X-Forwarded-For',
request.remote_addr)
    print(f"🔪 Request từ IP: {ip}")

    now = time.time()
```

```

        ip_counter[ip] = [t for t in ip_counter[ip]
if now - t < 10]
        ip_counter[ip].append(now)

        if len(ip_counter[ip]) > 30:
            send_log_to_siem(f"🚨 Phát hiện nghi ngờ
DDoS từ IP {ip}: {len(ip_counter[ip])} yêu cầu trong
10 giây")

```

3. Mã chương trình phát hiện tấn công XSS

```

def submit_rating_demo():
    # Lấy dữ liệu từ FormData (do frontend gửi
    lên)
    comment = request.form.get('comment', '')
    rating = request.form.get('rating', '')

    # Logic gửi log sang SIEM
    # Nếu nội dung chứa script/alert -> Gửi cảnh
    báo CRITICAL
    if "<script>" in comment or "onerror" in
    comment or "alert(" in comment:
        send_log_to_siem(f"🚨 PHÁT HIỆN TẤN CÔNG
XSS: {comment}", level="CRITICAL")
    else:
        send_log_to_siem(f"User đánh giá
{rating} sao. Nội dung: {comment}",
        level="INFO")

    return jsonify({'message': 'Đã gửi đánh giá
thành công!'}), 200

```

4. Mã chương trình phát hiện tấn công SQL Injection

```

def vulnerable_search():
    # Lấy tham số 'q' từ URL (giống biến 'title'
    trong tài liệu của bạn)
    q = request.args.get('q', '')

```

```

        # Gửi log nguyên thô sang SIEM để SIEM phân
        tích
        # (Gửi trước khi thực thi để bắt được cả khi
        query lỗi)
        send_log_to_siem(f"🔍 Vulnerable Search
        Request: q={q}")

        # --- LỖ HỒNG Ở ĐÂY ---
        # Nối chuỗi trực tiếp f"{q}" thay vì dùng
        dấu ? (parameterized)
        # Hacker có thể chèn: ' UNION SELECT ...
        sql = f"SELECT id, name, price, stock,
        image_url, description FROM products WHERE name
        LIKE '%{q}%'"

        try:
            with db_cursor() as cur:
                # Cho phép chạy nhiều câu lệnh
                (script) nếu cần, hoặc execute thường
                cur.execute(sql)
                rows = cur.fetchall()

                results = []
                for r in rows:
                    # SQLite trả về tuple hoặc Row,
                    convert sang dict
                    results.append({
                        "id": r[0],
                        "name": r[1],
                        "price": r[2],
                        "stock": r[3],
                        "image_url": r[4],
                        "description": r[5]
                    })

```

```

        return jsonify(results)

    except Exception as e:
        # Nếu SQL lỗi (do hacker dò cột), trả về
        lỗi để hacker nhìn thấy (Blind SQLi/Error based)
        error_msg = str(e)
        send_log_to_siem(f"✗ SQL Error:
        {error_msg}", level="CRITICAL")
        return jsonify({"error": "SQL Syntax Error",
        "detail": error_msg}), 500

```

5. Mã chương trình thực hiện phân tích và phản ứng các sự kiện

```

def receive_log():
    data = request.json or {}

    # 1) Lấy message (ưu tiên message/log/msg)
    msg = data.get("message") or data.get("log")
    or data.get("msg") or ""
    if not msg:
        msg = f"RAW={data}"

    # 2) Chuẩn hoá IP attacker (ưu tiên field
    ip, fallback regex)
    attacker_ip = (data.get("ip") or "").strip()
    or extract_ip_from_message(msg)
    msg_upper = msg.upper()
    msg_lower = msg.lower()

    # 3) Keyword/pattern phát hiện (giảm false-
    positive)
    sql_keywords = [
        "UNION SELECT",
        "ORDER BY",
        "INFORMATION_SCHEMA",
        "SQLITE_MASTER",

```

```

        "' OR 1=1",
    ]
    is_sqli = any(k in msg_upper for k in
sql_keywords)

    # 4) XSS (giữ đơn giản)
    is_xss = "xss" in msg_lower

    # 5) DDoS (theo message backend của bạn)
    is_ddos = "ddos" in msg_lower

    # 6) Xử lý theo ưu tiên: SQLi > XSS > DDoS >
Normal
    if is_sqli:
        # ☒ Chỉ 2 dòng cảnh báo
        alert_line = "💀 [SIEM ALERT] PHÁT HIỆN
TẤN CÔNG SQL INJECTION"
        evidence_line = f"{msg}"

        print(alert_line)
        print(evidence_line)

        # Lưu đúng thứ bạn muốn hiển thị ở UI
        save_log(alert_line)
        save_log(evidence_line)

        # Auto-block
        if attacker_ip:
            add_ip_to_blocklist(attacker_ip)

        return jsonify({"status": "received",
"type": "SQLI"}), 200

    elif is_xss:

```

```

        alert_line = "🚨 [SIEM ALERT] PHÁT HIỆN
TẤN CÔNG XSS"

        evidence_line = f"🔗 Payload: {msg}"

        print(alert_line)
        print(evidence_line)

        save_log(alert_line)
        save_log(evidence_line)

        if attacker_ip:
            add_ip_to_blocklist(attacker_ip)

        return jsonify({"status": "received",
"type": "XSS"}), 200

    elif is_ddos:
        alert_line = "🚨 [SIEM ALERT] PHÁT HIỆN
NGHI NGỜ DDOS"

        evidence_line = f"🔗 Evidence: {msg}"

        print(alert_line)
        print(evidence_line)

        save_log(alert_line)
        save_log(evidence_line)

        ip = attacker_ip or
extract_ip_from_message(msg)
        if ip:
            add_ip_to_blocklist(ip)

        return jsonify({"status": "received",
"type": "DDOS"}), 200

```

```
# 7) Bình thường: lưu msg gốc
save_log(msg)
return jsonify({"status": "received", "type":
"NORMAL"}), 200
```

6. Mã chương trình thực hiện tự động thêm IP của attacker vào danh sách chặn blocklist.txt

```
def add_ip_to_blocklist(ip: str):
    # validate ip
    try:
        ipaddress.ip_address(ip)
    except Exception:
        return

    # đọc danh sách cũ
    existing = set()
    if os.path.exists(BLOCKLIST_PATH):
        with open(BLOCKLIST_PATH, "r",
encoding="utf-8") as f:
            existing = {line.strip() for line in
f if line.strip()}

    # append nếu chưa có
    if ip not in existing:
        with open(BLOCKLIST_PATH, "a",
encoding="utf-8") as f:
            f.write(ip + "\n")
        save_log(f"☑ Added to blocklist: {ip}")
```